Computer Science Review 45 (2022) 100496

Contents lists available at ScienceDirect

Computer Science Review

journal homepage: www.elsevier.com/locate/cosrev

Review article

System security assurance: A systematic literature review

Ankur Shukla [a,*], Basel Katt [a], Livinus Obiora Nweke [a], Prosper Kandabongee Yeng [a], Goitom Kahsay Weldehawaryat [b]

[a] Department of Information Security and Communication Technology, Norwegian University of Science and Technology, Gjøvik, Norway
[b] Department of Building and Environmental Technology, Norwegian University of Life Sciences (NMBU), Norway

ARTICLE INFO

Article history:
Received 11 February 2022
Received in revised form 2 July 2022
Accepted 14 July 2022
Available online 3 August 2022

Keywords:
Security assurance
Security assurance methods
Security requirements
Security metrics
System and environments

ABSTRACT

System security assurance provides the confidence that security features, practices, procedures, and architecture of software systems mediate and enforce the security policy and are resilient against security failure and attacks. Alongside the significant benefits of security assurance, the evolution of new information and communication technology (ICT) introduces new challenges regarding information protection. Security assurance methods based on the traditional tools, techniques, and procedures may fail to account new challenges due to poor requirement specifications, static nature, and poor development processes. The common criteria (CC) commonly used for security evaluation and certification process also comes with many limitations and challenges. In this paper, extensive efforts have been made to study the state-of-the-art, limitations and future research directions for security assurance of the ICT and cyber–physical systems (CPS) in a wide range of domains. We conducted a systematic review of requirements, processes, and activities involved in system security assurance including security requirements, security metrics, system and environments and assurance methods. We highlighted the challenges and gaps that have been identified by the existing literature related to system security assurance and corresponding solutions. Finally, we discussed the limitations of the present methods and future research directions.

© 2022 The Author(s). Published by Elsevier Inc. This is an open access article under the CC BY license (http://creativecommons.org/licenses/by/4.0/).

Contents

1. Introduction ... 3
2. Related works and the need of this survey ... 4
3. Methodology of SLR ... 5
   3.1. Review planning ... 5
      3.1.1. Purpose of SLR ... 5
      3.1.2. Developing review protocol ... 5
      3.1.3. Review protocol evaluation ... 5
      3.1.4. Specifying research questions ... 5
   3.2. Conducting the review ... 5
      3.2.1. Identification of research ... 5
      3.2.2. Study selection ... 5
      3.2.3. Reliability of inclusion decisions ... 6
      3.2.4. Study quality assessment ... 6
      3.2.5. Practical literature screening ... 6
      3.2.6. Data extraction ... 6
   3.3. Review report ... 6
4. Security assurance: Definition, process, and types ... 6
5. Common criteria for security assurance ... 7
   5.1. Limitations of common criteria ... 9
6. Security assurance: Challenges and gaps ... 9
   6.1. Elucidation, modelling, and validation of security requirements ... 9

* Corresponding author.
E-mail address: shukla395@gmail.com (A. Shukla).

https://doi.org/10.1016/j.cosrev.2022.100496
1574-0137/© 2022 The Author(s). Published by Elsevier Inc. This is an open access article under the CC BY license (http://creativecommons.org/licenses/by/4.0/).

6.2. Security assurance of composed system ... 9
6.3. Security assurance in operational phase ... 10
6.4. Service-oriented security assurance ... 10
6.5. Security assurance tool ... 10
6.6. CC protection profile for trusted computing features ... 10
6.7. Automation of security assurance ... 10
6.8. Identification and prediction of security vulnerability ... 10
6.9. Security in system development life cycle ... 10
6.10. Cloud security assurance ... 10
7. Security goals, requirements and metrics ... 11
7.1. Security goals ... 11
7.2. Security requirements ... 11
7.2.1. Elicitation, tracing, and analysis of the security requirements ... 12
7.2.2. Security requirements modelling ... 12
7.2.3. Correctness of the security requirements ... 12
7.2.4. Measurement requirements ... 12
7.3. Security metrics ... 13
7.3.1. Quality criteria of security metrics ... 13
7.3.2. Security metrics management and measurement ... 13
7.3.3. Security metrics model for operational security ... 14
7.3.4. Security metrics taxonomy for run-time systems ... 14
8. Security assurance methods ... 14
8.1. Security assurance framework ... 15
8.2. Object-oriented approach ... 16
8.3. Security assurance development process model ... 18
8.4. Vulnerability detection/prediction approach ... 18
8.5. Model-driven Cyber Range training ... 18
8.6. Useable-security assessment ... 19
8.7. Security assurance tools ... 19
8.8. CC ontology tool ... 19
9. System and environments ... 19
9.1. Security assurance in access control ... 19
9.2. Security assurance of the self-adaptive system ... 21
9.3. Core-level cybersecurity assurance ... 21
9.4. Security assurance of telecommunication system ... 21
9.5. Security durability of web application ... 22
9.6. Security assurance framework for intelligent transport system ... 22
9.7. Security assurance of network traffic ... 22
9.8. Security assurance of IoT devices ... 22
9.9. Security assurance framework for OSS ... 23
9.10. Wireless Local Area Networks (WLANs) ... 23
9.11. Security assurance of E-governance ... 23
9.12. Protection profile in railway automation ... 23
9.13. Cloud security assurance ... 23
9.13.1. Enforcement of security properties in cloud ... 23
9.13.2. Security assessment of cloud considering CSPs and CSCs requirements ... 24
9.14. Continuous security assessment for security certification of cloud ... 24
9.14.1. Security transparency and audit ... 24
9.14.2. Enforcement and monitoring the SecSLAs ... 24
10. Limitations and future research directions ... 25
10.1. Security requirements analysis ... 25
10.2. Enforcement of security requirements ... 25
10.3. Correctness, quality and effectiveness of the security assurance ... 25
10.4. Real-time security assurance evaluation ... 25
10.5. Automation of security assurance process ... 25
10.6. Security assurance tool ... 26
10.7. Security assurance of composed system ... 26
10.8. Quantitative security assurance approach ... 26
10.9. Competencies of individuals ... 26
10.10. Development of metrics visualization system ... 26
10.11. Data driven security assurance method ... 26
10.12. Vulnerability assessment ... 26
10.13. Cloud security assurance ... 26
10.13.1. Security monitoring tool ... 26
10.13.2. Real-time cloud security assessment ... 26
11. Conclusion ... 26
Declaration of competing interest ... 27
Acknowledgements ... 27
Appendix. Keywords for data extraction and their definitions ... 27

References 27

1. Introduction

Recent advancements in information and communication technologies have revolutionized the entire social and economic systems. In this information age era, government and commercial organizations heavily rely on information to conduct different activities. Alongside significant benefits, the ever-increasing criticality, connectivity, and comprehensiveness of software-intensive systems introduce new challenges for cybersecurity professionals to protect the information. Compromise in confidentiality, integrity, availability, accountability, and authenticity of information and services can harm the operation of the organizations, and it is needed to protect the data and information of IT systems within the organization. Therefore, it has become a crucial task for security researchers and practitioners to manage the security risks by mitigating the potential vulnerabilities and threats with the help of new techniques and methodology and achieve the acceptable security assurance of an IT system so that the stakeholders can get greater confidence that the system is performing in intended or claimed way with acceptable risks.

Several definitions of security assurance can be found; however, the common basis of these definitions refers to the trust and confidence in the secure and correct operation of (software) systems. NIST defined security assurance as a "measure of confidence that the security features, practices, procedures, and architecture of an information system accurately mediates and enforces the security policy" [1]. Katt and Prasher [2] defined security assurance as "the confidence that a system meets its security requirements and is resilient against security vulnerabilities and failures". They further defined confidence as the level of trust of a system that is safe to use. However, there is a difference between the "security need" and "security assurance". Jelen and Williams [3] pointed out this fact and defined security needs as a threshold value on that the measurement of actual level can be made. The security level can be measured by comparing the measured value and the threshold value; however, the confidence of the calculation depends on the accuracy of the measurement. Considering these aspects, they defined assurance as "a measure of confidence in the accuracy of a risk or security measurement".

Security assurance has always been the keen interest of researchers and practitioners. Security assurance tries to address two essential questions "Does a system do what it is supposed to do" and "Does the system do anything unintended?" [4]. Security assurance activities go throughout the development life cycle of the software system from initiation of the protection profile to certification of a target of evaluation (TOE), which is the system that will be assessed and evaluated. Security assurance is also continued when the system is in the operational phase. Different scanning tools can be used to ensure and maintain the continued security by locating and patching security errors and vulnerabilities. Security testing and evaluation are beneficial to get the desired level of security assurance. However, there is no single standard process available to measure the security assurance of the software system. One can get certain degree of confidence regarding the system's security and its components by reviewing its development process. The level of confidence can be increased if a rigorous methodology of security requirement definition, design, specification, and conformance have been considered. The past users' experience on a particular system can also provide some degree of assurance. On the other hand, if multiple organizations use a system without any security incidents, one can trust that it will operate securely in their organization. Application of some new technologies such as advanced software engineering also provides assurance.

In the past, various standards and frameworks have been developed to evaluate the security assurance of the system. The initial effort was made by Trusted Computer System Evaluation Criteria, a United States Government Department of Defense standard, which is also known as the Orange Book, to assess the system's security. Some other efforts have been made in this continuation, such as European developed Information Technology Security Evaluation Criteria(ITSEC), Canadian Trusted Computer Product Evaluation Criteria (CTCPEC), ISO SC27 WG3 security evaluation criteria, etc. Later, these criteria are primarily integrated into single criteria, i.e., CC. OWASP Application Security Verification Standard (ASVS) is an open standard that can be used for technical security control testing of web applications. OWASP also provides the requirements list to developers for secure development. Software security maturity models lay out the requirements of different security levels and software engineering and maintenance practices that fulfil those requirements. Some examples of software security maturity models are Building Security In MaturityModel (BSIMM), BSIMM for vendors (vBSIMM), and OWASP's Software Assurance Maturity Model (OpenSAMM) [5,6].

In the past, several efforts have been made for system security assurance and its evaluation. The major focuses of these researches are to provide solutions to ensure the security of the systems used in various application domains and environments by developing security assurance methods and techniques. These solutions include different methods, techniques, processes, and recommendations such as operational security assurance, security assurance requirements engineering methodology, security assurance metric and aggregation techniques, etc. These works also include developing security assurance methods for composed systems that are made with different components such as protocols, servers, clients and services. Some efforts have also been made towards early detection of security vulnerabilities, development of a security assurance model, and security assurance tools to maintain and enhance the security of the deployed system. Security assurance is also essential for the software developers to address the security concerns in the early development and acquisition phase, and to measure their preparation towards the advancement of secure software. The development of secure software requires considerations beyond the basic security requirements such as authentication/authorization and mandated operational compliance to identify and resolve the risk environment in which the system must operate. Some authors have considered the security assurance methodology in the different development life cycles of the software. However, these methods and techniques come with several drawbacks. The main drawbacks of these approaches are that they are static, time-consuming, and do not scale well to the extensive, networked, IT-driven system. It also does not offer continuous security assurance. Many researchers have made efforts to resolve these challenges. However, it is still an open issue.

In the past, no significant efforts have been made on systematic literature review (SLR) on system security assurance. Some studies can be found; however, they focused on a particular security concern of a specific application or application domain. Therefore, one cannot get a clear and comprehensive overview of the existing security assurance approaches, related information, and evidence. Therefore, a detailed and systematic literature review on "System Security Assurance" has been conducted in this paper. The motive of this paper is to study state-of-the-art, research trends, limitations, and future research directions in

Table 1
Details of related works, their limitations, and enhancement in this paper.

Year	Paper	Topic(s)	Contributions	Limitation	Enhancements in our paper
2009	[7]	Software assurance	Investigated research on software assurance and proposed a software assurance system	Considered security flaw related to software installation and vulnerability related to software execution only.	Focuses on general security assurance and considered security requirements and vulnerability in a wide range of application domains.
2013	[8]	Communication security using formal models	A survey of formal models of communications security and taxonomy of security concerns.	Focused on communication security using formal models.	Considers on the overall system security assurance.
2013	[9]	Security-related behaviour	A review on security-related behaviour in the workplace and a framework for conceptualizing security-related behaviour.	Mainly focused on security-related behaviour.	Considers broader aspect of security assurance
2014	[10]	Security of Open multi-agent systems	A survey on security techniques for multi-agent systems.	Focused on multi-agent systems and do not consider security assurance methods.	Considers security assurance for wide range of application domain.
2014	[11]	Context-aware security solutions for CPSs	A survey on the state-of-the-art of CPSs to identify the security issues and an investigation the role of context-awareness to improve the extent of CPS security.	This survey is very limited and mainly focused on context-aware security solutions.	Extensive review on security assurance of CPS.
2015	[12]	Development of secure software using agile approach	Literature review of the challenges in the development of security software using agile approaches.	This work is very limited and mainly focused on the agile method in the development of secure software.	Extensive review which is not method based and considers every software development life cycles.
2015	[13]	Security of information systems	A survey on security of information systems	This work do not consider security assurance and evaluation processes.	Presents a detailed overview of security assurance and evaluation in a wide range of domains.

security assurance of the ICT and CPSs in a wide range of domains. It will also investigate the conventional and emerging technology for security solutions. This paper provides detailed information and discussion on the research challenges and gaps, the efforts made towards these challenges and gaps, limitations of these approaches, and future research directions.

The rest of the paper is organized as follows: In Section 2, the existing works related to the security assurance survey have been discussed and the need for the survey has been established. Section 3 presents a detailed discussion of the methodology of the SLR. In Sections 4–6, the detailed discussion about security assurance process, the role of CC, and challenges and gaps in the existing methods and technology have been discussed respectively. Security requirements and security metrics is discussed in Section 7. Section 8 presents the different security assurance methods. Security assurance methods developed and applied on different systems and environments is given in Section 9. In Section 10, limitations and future directions is discussed. Finally, Section 11 concludes this paper.

2. Related works and the need of this survey

In the past, very limited surveys have been published related to system security assurance. However, no dedicated works that consider detailed and systematic study covering processes and activities involved in system security assurances could be found. In this section, the existing surveys have been summarized and compared with our work. As observed in the literature, most of the works do not follow the systematic methodology in conducting the literature review. These works are either focused on a specific application domain or considered only limited aspects of the security assurance process. Summary of the topic covered in the existing literature, their contributions and limitations are given in Table 1. The enhancement made in our work is also given in this table.

Choi and Yoo [7] conducted a study on software assurance and discussed the critical security flaws and vulnerabilities related to software installation and software execution. They proposed a system for software assurance. This study incorporates some issues related to software security. This study considered the researches carried by limited government agencies and research institutes.

Brown [8] surveyed the various hierarchically ordered and adjacent sciences, notations, and security requirements analyses which are essential for extensive communication security. They developed a taxonomy that provides a comprehensive framework for identifying and analysing security requirements and potential attacks. This study is focused on formal methods in securing the system.

Guo [9] discussed the security-related behaviour in the workplace. They reviewed different concepts of security-related behaviour and developed a framework for conceptualizing security-related behaviour to delineate and synthesize the difference between the divergent concepts. This research work is focused on security-related behaviour and does not consider other security perspectives.

Bijani and Robertson [10] conducted a review of security techniques in literature and suggested the appropriate security technique for a class of attacks in open multi-agent systems. Wan and Alagar [11] studied the state-of-the-art of security of CPSs. The focus of this study is to provide context-aware security solutions for CPSs. Ouchani and Debbabi [14] conducted a review to study the state-of-the-art of security requirements specification, attack modelling, security requirements verification, and security quantification for the software and systems that are based on Unified Modelling Language (UML) or Systems Modelling Language

(SysML). Oueslati et al. [12] conducted the literature review to identify the challenges and issues in the development of secure software using the agile approach. Zhang et al. [13] surveyed cybersecurity. They discussed the research and development in cybersecurity.

The current literature covered various security issues and challenges in different domains and investigated the conventional and emerging technology for security solutions. However, the survey which is focused on system security assurance is still missing. On the other hand, most of the present works do not follow the systematic process in the literature review. Due to this, the existing reviews fails to deliver a clear and comprehensive overview of the available information and evidence on system security assurance. Also, they fail to identify the actual research challenges and gaps in this field. We conducted a systematic and extensive review of system security assurance in this paper to overcome this situation.

3. Methodology of SLR

A SLR provides a systematic, explicit, and reproducible way to identify, select, evaluate, and critically appraises the existing body of completed and recorded research works [15]. The main motive of this SLR is to evaluate and interpret the recent research on system security assurance to address the current research problems and challenges. To conduct the systematic and fair evaluation of literature, a review protocol has been established. The construction of guidelines for this SLR is derived from the "Guidelines for performing Systematic Literature Reviews in Software Engineering" [16]. Some other guidelines for systematic review have also been reviewed [17] to developed the review protocol.

The guidelines established for this SLR include mainly three steps: review planning, conducting the review, and review report.

3.1. Review planning

In this stage of the SLR, the following points have been addressed:

3.1.1. Purpose of SLR

The main purpose of this literature review is to study the current challenges and gaps in system security assurance. This SLR will conduct a detailed study of system security assurance requirements, metrics, frameworks, and methods. The security assurance of different systems and environments in a wide range of applications domains will be discussed. Specifically, the purpose of this SLR can be summarized as follows: (a) to study essential background, state-of-the art, research trends and directions in system security assurance, and (b) to develop a taxonomy on system security assurance.

3.1.2. Developing review protocol

A review protocol is developed with the detailed review of the existing methodology of SLR and discussion with the experts. This protocol includes the design of research questions, search strategy, and potential resources. Furthermore, study selection criteria, selection procedure, and quality assessment checklists have been described in this protocol. In the protocol, the data extraction strategy and synthesis of the extracted data have been specified. The protocol is also focused on some other planning and management information such as dissemination strategy and project timeline.

3.1.3. Review protocol evaluation

The review protocol has been reviewed rigorously against the following criteria:

(i) Whether search strings are appropriate and match with the research questions?
(ii) Whether points of the data extraction will address the research questions properly? and
(iii) Whether analysis procedure is appropriate to fulfil the objectives of the SLR?

3.1.4. Specifying research questions

The following research questions have been considered of this SLR based on reflection, debate, and reformulation:

RQ1. What are the current trends and results related to security assurance considering process, methods, guidelines, tools, metrics, evaluation/techniques, automation, standards, and application domains?
RQ2. What are the challenges, limitations, and gaps related to security assurance?
RQ3. What are the future directions/trends related to security assurance?
RQ4. How can we categorize/classify the different research activities related to security assurance?

3.2. Conducting the review

After the proper establishment of the review protocol, the review process started.

3.2.1. Identification of research

Identification of primary studies related to the research questions using an unbiased search strategy is an important step. Initially, some search strings are derived from the research questions. These search strings are constructed using Boolean ANDs and ORs. These search strings are tested against the existing primary studies on system security assurance from well know databases. Based on the testing results and discussion with the expert, two search strings are finalized, which are: (i) "Security Assurance", and (ii) System and Security and Assurance.

Thereafter, an exhaustive search has been performed considering the six electronic sources including: IEEExplore, ACM Digital library, Google Scholar, Science Direct SpringerLink, and Wiley online library.

3.2.2. Study selection

After identifying the potential relevant primary studies, they need to be assessed based on their relevance. Selection criteria are helpful in identifying and selecting primary research studies that provide evidence for the research questions. Therefore, selection criteria have been decided based on the research questions to reduce the likelihood of bias. In this SLR, the following inclusion criteria have been used:

(a) Papers that were published between 2004–2020.
(b) Papers that focus on the security assurance assessment and evaluation of the systems, for example, security requirement analysis, security assurance framework, and security models.
(c) Security assurance papers that focus solely on ICT and cyber–physical systems.

The exclusion criterion is "papers that are not related to information and communication technology or cyber–physical system". The selected papers were also updated continuously, and the last update was made in March 2021. We have selected the starting year 2004 because we aim to study the recent developments in system security assurance over the last one and half decades.

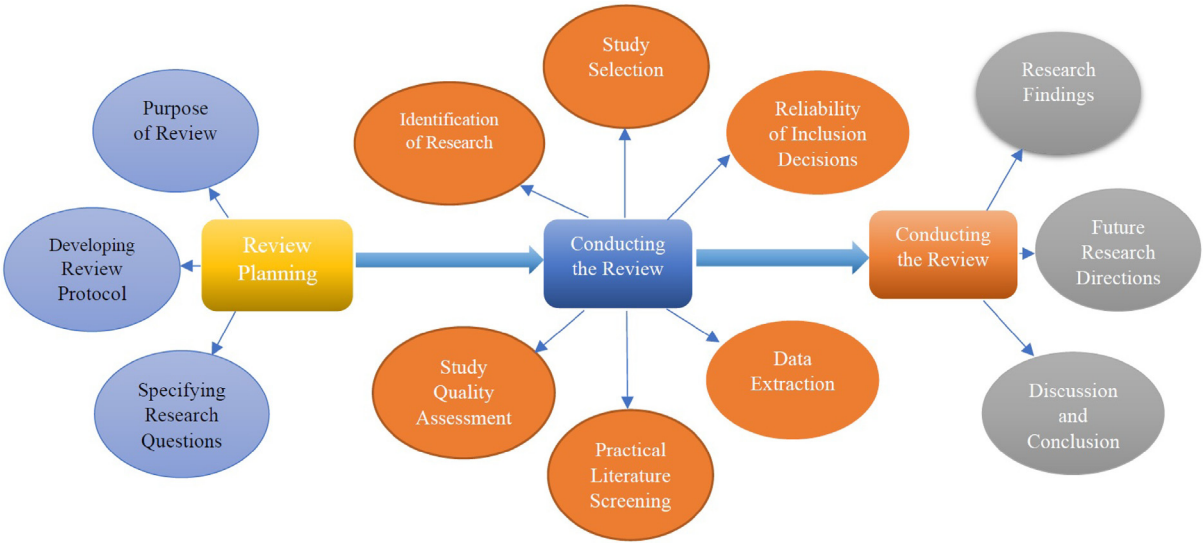


Fig. 1. Methodology of SLR.

3.2.3. Reliability of inclusion decisions

To improve the reliability of the inclusion decisions, each electronic source is assigned to two researchers. Accordingly, each paper is assessed by two researchers based on the inclusion and exclusion criteria. To measure the agreement between researchers, a list of included/excluded papers with the reason for inclusion/exclusion has been maintained. In case of disagreement or misunderstanding on any paper, it has been discussed in the common meeting of the group and resolved by discussion and with expert advice.

3.2.4. Study quality assessment

After collecting all potentially eligible articles, the next step is the quality assessment to examine the articles more closely. The primary purpose of the quality appraisal is to conduct the second screening to eliminate the articles that are not relevant to this study. As a result, in addition to general inclusion and exclusion criteria, it is essential to examine the quality of primary studies. Considering this fact, now stricter criteria have been established. The followings are the quality assessment criteria: (a) are the aims clearly stated? (b) is the research method used appropriately? (c) does the research work evaluate the outcome appropriately? and (d) does the research work allow the questions to be answered?

3.2.5. Practical literature screening

Considering the above steps and criteria, the literature screening has been conducted. Results of the different rounds are as follows:

(a) Round 1: The literature is searched and collected from different electronic sources. In this round total of 733 literature items were collected. The duplicate entries were also eliminated and after elimination, the remaining number of literature items are 564.
(b) Round 2: In this round, quality assessment of the literature was conducted using the aforementioned quality assessment criteria, resulting in a total of 90 literature items.

3.2.6. Data extraction

The data extraction form has been designed to collect helpful information to answer the research questions. The data extraction form has been piloted on a sample of a preliminary study to assess the form's completeness and avoid any technical issues. The different points of the data extraction form have been decided based on the research questions, and each point has been defined clearly to avoid misunderstanding, misinterpretation between the researchers. The key points of the data extraction form and their definitions are given in Appendix.

3.3. Review report

The report or writing the review is the final step of developing a research literature review. The process includes reporting and writing the findings systematically and smoothly so that the entire process can be reproducible scientifically. A pictorial illustration of the SLR methodology of this survey is shown in Fig. 1.

4. Security assurance: Definition, process, and types

We define system security assurance as *the confidence that a system meets its security requirements and is resilient against security vulnerabilities and failures*. Security assurance is a complex and time-consuming process that goes throughout the development life cycle of a (software) system begins from the protection profile initiation to the TOE certification. The security assurance process of a system requires a set of inputs such as TOE, the operational environment, assessment criteria and requirements (assurance profile), assurance methods, and assurance level [2]. This process goes through multiple stages and involves various activities such as defining security goals, security requirement analysis, threat analysis, vulnerability analysis, penetration testing, security audit, scoring, and analysis, etc. The output of the security assurance process provides the security assurance level and other useful information, recommendation, and mitigation plan that help stakeholders to improve confidence, align with best practices, and reduce the risk following a cyber-attack. The security assurance process and its essential components are presented in Fig. 2. There are different types of security assurance as given in Fig. 3.

(a) Operational security assurance

Assurance activities are crucial during the operations and maintenance phase to ensure that the assurance level of a system to which it is certified, is maintained. The security requirements

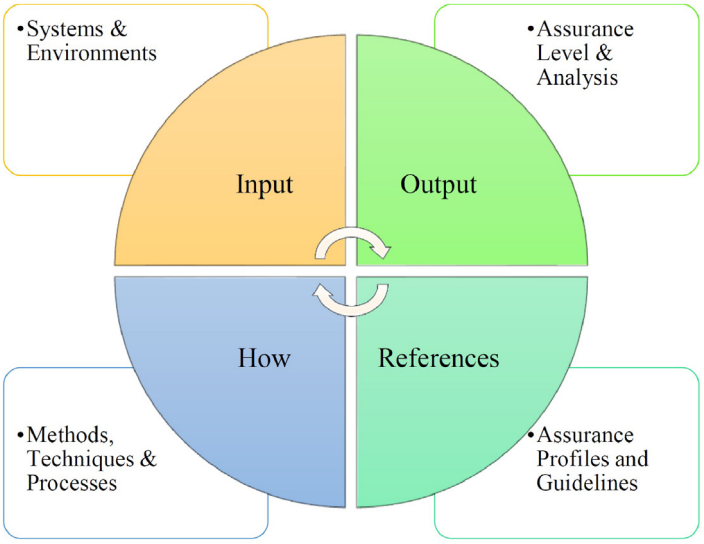


Fig. 2. Security assurance process.

specified for a system may be violated in the operational phase because of improper implementation of the security measures, hazardous environment, or invalidity of the assumptions under which the security requirements were specified [18]. In other words, the security requirements identified during the development phase based on the assumption made on the system's operational environment may no longer be valid if there are any changes in the system environment. Therefore, it is required to collect evidence to verify the fulfilment of security requirements of the system in the operational phase [19]. Therefore, one should also focus on security assurance after the deployment or implementation phase. The security assurance evaluation of the system in operation comes with many challenges as well as benefits that cannot be accomplished by an offline assessment. The operation security assurance is complex due to the openness, aggregation, and dynamics nature of IT and cyber–physical systems [20].

(b) Continuous security assurance

Organizations are struggling to ensure security a routine element of their operations. They are exposed to a number of risks that necessitate the deployment of compliance and security controls. Continuous security assurance can be a potential way to manage these risks with continuous monitoring, continuous compliance, and continuous security [21,22]. On the basis of evidence collecting, continuous security assurance also reports if the security requirements are met throughout system operation [19].

(c) Optimal security assurance

It is not possible to make the software systems completely secure. Some vulnerabilities may be present, which were not fixed during the development process due to time constraints or other reasons, and these must be re-examined, prioritized, and fixed. Security assurance is a very time-consuming and costly process. Optimal security assurance aims to provide optimal security and to reduce these costs [23] (see Fig. 3).

(d) Useable-security assurance

The security goals are mainly focused on the user's demand, and demands are changed when there is a change in their requirements. The security goals can be achieved through the rigorous testing, establishment, and assessment to provide the defense against malicious attacks. However, the system user can sometimes be the weakest link and may unintentionally invite attacks. Therefore, it is vital to secure the system from the threat as well as maintain usability. The usability focus on the ease of users 'keeping simple' formula [24,25].

(e) Service-oriented security assurance

The business decomposition process into services is a possible way to provide the flexibility to adapt to the changes in the business needs of the enterprises. This can be provided by a service-oriented architecture, which allows the user to find and use services dynamically. On the other hand, security in service selection is also a crucial factor. Therefore, service-oriented assurance is required to evaluate the security of sub-services. Data from various sources are required to assess the security properties in this process. In addition, the system states (such as established security policies), events, certificates, and other security verification evidence from the third parties are required. The study proved that security properties could be specified and verified objectively in various services using the security-oriented assurance model [26].

(f) Core-level security assurance

The operating system core can be considered instead of the application level service in order to increase the speed and effectiveness of attack detection. The main advantage of considering the operating system's core is that it contains every internal attribute and the file system [27].

5. Common criteria for security assurance

The meaning of security may vary from person to person and from organization to organization. Therefore, common security standards are essential for IT systems with complex and diverse configurations. In this regard, the need for CC was realized to evaluate the security of an IT product. The origins of the CC are discussed in the Introduction section. The CC for information technology security evaluation is a well-known international standard (ISO/IEC 15408) for computer security certification.[1]

[1] https://www.commoncriteriaportal.org/cc/

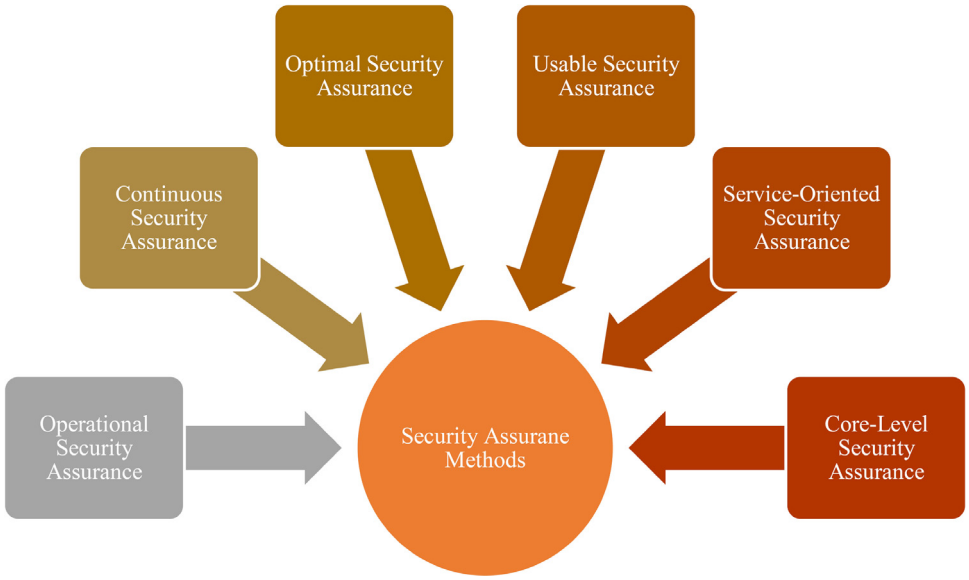


Fig. 3. Different types of security assurance.

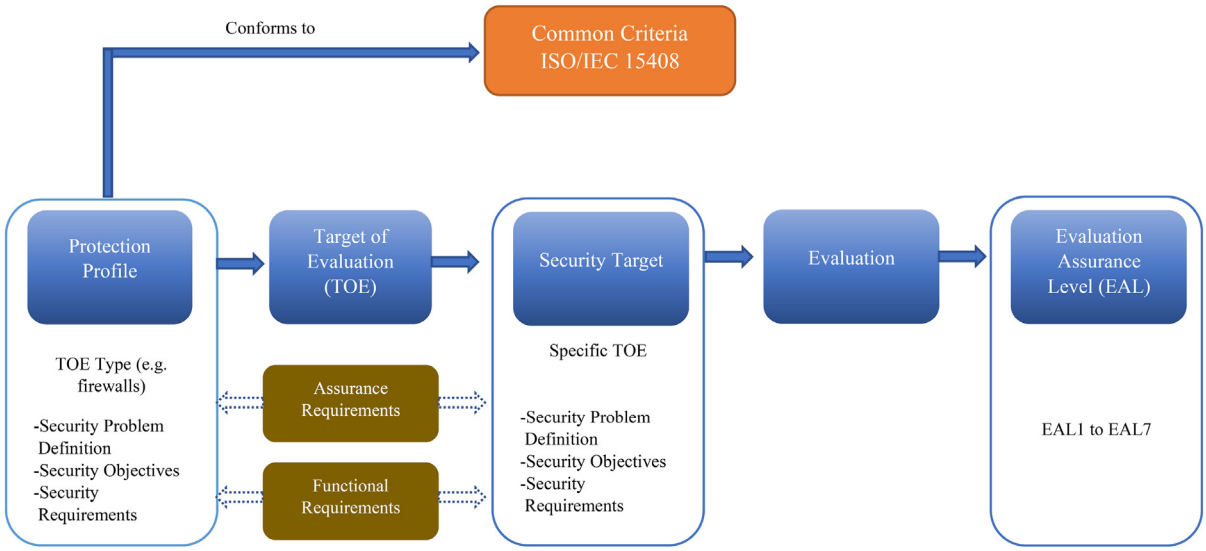


Fig. 4. CC evaluation framework.

The current version of CC is 3.1 revision 5. It provides a set of guidelines and specifications that can facilitate the specification of security functional requirements and security assurance requirements. While the security functional requirements define the expected security behaviour of information security products and systems, the security assurance requirements demonstrate that the security attributes have been implemented correctly. CC evaluation framework is given in Fig. 4.

The general objective of CC is to provide a framework that allows users to specify security functional requirements, enable the developers to specify the security attributes, and help evaluators to ascertain if the security attributes as defined by the developers meet their claims. The use of CC in the development of information security products and systems can improve the overall security of the products and reduce the time and cost of IT security evaluation. For example, Kim and Leem [28] showed a method that employs CC in the development process to improve the security of software products. They used a case study that involves the development of MTOS7.5, a security-enhanced UNIX-like operating system based on BSD 4.4 according to EAL3 in CC. The results from their study indicated that CC applied to the development process of software products can enhance the security of the products, reduce the time and efforts in developing the products, and shorten the evaluation periods of the products.

CC can also be used at the early stages of the software lifecycle to integrate requirement engineering and security engineering to develop secured information systems. This approach is proposed by Mellado et al. [29] and involves the use of a CC-centred and reuse-based process to address security requirements at the early stages of software development. The authors utilized a security repository that they combined with CC and then applied to the early stages of the software life cycle. The objective was to merge the ideas of requirement engineering and security engineering.

In the literature, other works can be found that have used CC in the development process of information security products, requirement engineering, security engineering, and certification process. Some of them are discussed in the upcoming sections.

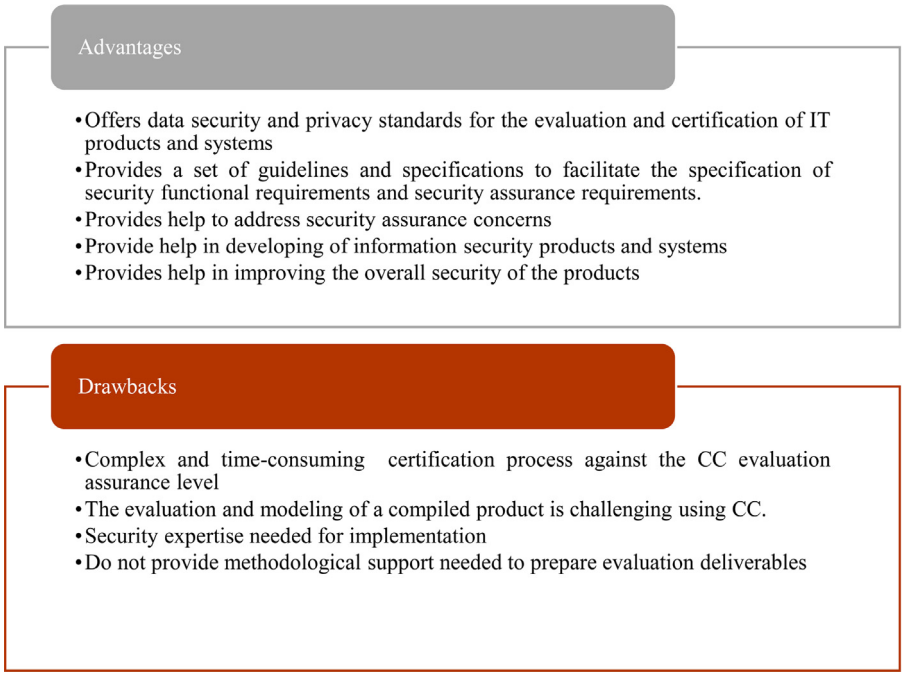


Fig. 5. CC advantages and drawbacks.

5.1. Limitations of common criteria

In addition to the many advantages of CC, there are also several limitations, including

(a) *Complex Certification Process*: The certification process of a product or a system against the CC evaluation assurance level is very complex and time taking particularly for higher evaluation assurance levels [30].
(b) *Evaluation and Modelling of Composed Systems*: The CC has been focused on a specific product that is made up of a single software component. It is needed to provide methodological support for the evaluation and modelling of security of composed products composed of two or more evaluated or unevaluated components [31].
(c) *Security Expertise Needed for Implementation*: The security standard ISO 15408 CC provides support in developing a secure system in terms of the knowledge, security expertise, and guidelines needed including secure design technique such as UMLsec. However, CC has formulated the security guidelines and expertise in security domain terminology, making it difficult for non-security developers or stakeholders to understand. Therefore, some general security and design experience is required to get complete benefit of the CC [32].
(d) *Lack of Methodological Support for Preparing Evaluation Deliverable*: For CC-based IT products and systems security evaluation requires evaluation deliverable such as development documents that consist of functional specification and high-level design, and operational documents that consist of guidelines documents for users and administrators, and vulnerability analysis. Preparation of evaluation deliverable at the later stage of the development or after the product is developed may require extra costs and time. In evaluation deliverable preparation, CC does not provide any support in terms of methodology [28].

A summary of advantages and drawbacks related to the CC evaluation framework is given in Fig. 5.

6. Security assurance: Challenges and gaps

As discussed in this section, the existing literature addresses the following challenges and gaps:

6.1. Elucidation, modelling, and validation of security requirements

The specified security requirements may often be violated after the implementation phase because of improper deployment, change in requirements, hazardous environment, or invalidation of the assumption under which the security requirements were specified. Therefore, an approach is needed to complement security requirements engineering methodologies to check if the security requirements elucidated in the development phase are implemented correctly [19]. Several methods focused on elicitation and modelling the security requirements in the early development phase of the system. However, these methods have not been widely adopted because they are not easy to apply to the industries due to mismatch between the current development process and these methodologies. These methodologies are also very complex and do not provide documentation process of security properties of the IT systems [33].

6.2. Security assurance of composed system

Security assurance measurement of a complex software system is essential but not always possible. The modern software systems are composed of several components such as servers and clients, protocols, and services. Security weakness or vulnerability in any of these components may compromise the entire system. Therefore, a process or methodology is required to assure the security of software components used in a wide range of applications [34,35]. However, considering the relationship between these entities, a reverse process is also needed to combine the security values of the decomposed entities to obtain the security of the entire system [36].

6.3. Security assurance in operational phase

The existing offline security assurance evaluation approaches to measure and evaluate cyber security are not effective and widely accepted approaches as it does not provide continuous security assurance assessments for complex operational software systems. Therefore, a process, method, or tool is needed for the operational security assurance assessment [37,38].

6.4. Service-oriented security assurance

Service-oriented architectures decomposes the process into services hosted on the platform, which can adapt to changing load and performance requirements, and allow users to dynamically discover and use sub-services. However, security is not considered in the selection of services and sub-services. Therefore, service-oriented assurance is required to assure the security assurances of services as well as assess the security of sub-services [26].

6.5. Security assurance tool

Security assurance tools help to improve the system security by building security into software systems or determining how secure it is. There is a need for a security assurance tool that measures the system's security level so that it can be improved and maintained overall [39,40].

6.6. CC protection profile for trusted computing features

A protection profile is a document that assists in formulating a set of objectives and requirements for a specific category of products based on CC. Protection profile products can be validated and certified against the protection target. There exist some protection profiles for secure operating systems; however, no appropriate protection profile is available that considers trusted computing features such as trusted channels, trusted boots, and sealing [41].

6.7. Automation of security assurance

Automated information security analysis, validation, evaluation, and testing approaches are required to obtain the evidence regarding security strength or security performance in the software products and telecommunication system [42]. On the other hand, automation of the security assurance process in open source software is also essential. Since open-source software is subjected to frequent updates, therefore automation process should be able to incorporate these updates [43].

6.8. Identification and prediction of security vulnerability

Early identification of security vulnerabilities in the source code is an essential and challenging task in the software development process. Vulnerabilities can affect the system's confidentiality, integrity, and availability and thus cause severe damage to an organization [44].

6.9. Security in system development life cycle

Security in the entire software development process, starting from the requirement engineering to its final deployment, needs to be considered [45]. On the other hand, the security assurance throughout the system development life cycle is also important [46].

(a) *Security Design and Verification:* During the development life cycle, poor design practices such as the improper design of security functionality is a big security concern. Therefore, a process or a tool is required to design and develop a secure software system. On the other hand, verification and certification of designs and codes are also crucial [40].

(b) *Security Assurance of Access Control Enforcement Code:* Security assurance is an essential property of the application code that has not been addressed before. It is important to ensure that the code behaves with the access control policy consistently [47].

6.10. Cloud security assurance

Cloud computing is the most enticing technology which offers economical and technological benefits in the different service provisioning domains. However, the increasing popularity of cloud services comes with concerns about the security assurance of its different services. Enforcement of security properties in a cloud is a challenging task. There are different security-related challenges that cloud service providers (CSPs) or cloud service customers (CSCs) face, such as

(a) *Security Assurance Evaluation*
Businesses or organizations want to be assured that the cloud platform on which their infrastructure will be deployed is secure and will remain secure. Moreover, CSCs need to trust the CSPs with confidentiality, integrity, availability, and auditing in the cloud. Therefore, a security assurance methodology is required in order to obtain firm evidence that the security requirements of the companies are well defined and enforced [48]. There is a need for a method for both CSCs and CSPs to evaluate and compare the security assurance of offered services either qualitatively or quantitatively. It will enable CSCs to choose appropriate cloud services and CSPs to improve their service to gain better trust and meet customer security needs [49].

(b) *Security Assurance of Multi-cloud applications*
Security assurance of the multi-cloud applications, which consume and orchestrate services from multiple independent CSPs, is a challenging and unsolved issue [50].

(c) *Security Controls: Implementation and Effectiveness*
Cloud ecosystems employ a variety of security controls to ensure security and privacy. Security properties that have been enforced in the cloud environment must be effective. However, it is a challenging task to measure their effectiveness in operation. Therefore, a method is required which can assure whether security controls are adequate and appropriate for specific cloud ecosystems [51].

(d) *Security Monitoring and Analysis*
A monitoring methodology is required to monitor the security [52]. Moreover, an analysis tool is required for systematic security analysis of the critical cloud services [22].

(e) *Security Transparency and Auditing*
Security transparency and auditing are two other essential factors that industries must consider to maintain and increase trust in offering services. Lack of security transparency in cloud-based services demotivates organizations from embracing the technology. The existing methods do not provide a definite method that helps in achieving security transparency as per users' requirements [53].

A summary of challenges and gaps in system security assurance in given in Table 2.

Table 2
Challenges and gaps in system security assurance.

S.N.	Category	Challenges and Gaps	Descriptions	SDLC	Paper
1.	Security assurance	Security assurance of the composed systems	-A process or methodology is required to assure the security of software components - A reverse process is needed to combine the security values of the decomposed entities to obtain the security of the entire system	Operational phase	[34,35] [36].
		Security assurance in the operational phase	Offline security assurance evaluation approaches are not effective and do not provide continuous security assessments	Operational phase	[37,38].
		Service-oriented security assurance	Existing methods do not consider security in the selection of services and sub-services.	Operational phase	[26].
		Security assurance tool	Need for a tool for security assurance	Operational phase	[39,40].
		Automation of security assurance	Need of automated information security analysis, validation, evaluation, and testing approaches	Operational phase	[43]
2.	Security Requirements	Elucidation, modelling, and validation of security requirements	-To verify that the security requirements elucidated in the development phase are implemented correctly — Existing methods are not widely accepted and difficult to apply	Development and operational phase	[19][33].
		Design of security functionality	-Improper design of security functionality	Design phase	[40].
		Security assurance of access control enforcement code	-To ensure that the code behaves with the access control policy consistently	Coding phase	[47].
3.	Protection Profile	CC protection profile for trusted computing features	No appropriate protection profile is available that considers trusted computing features such as trusted channels, trusted boots, and sealing	Operational phase	[41].
4.	Vulnerability Analysis	Identification and prediction of security vulnerability	-Early identification of security vulnerabilities in the source code	Design phase	[44]
5.	Cloud Security Assurance	Security assurance evaluation	A methodology is required to obtain firm evidence that the security requirements are well defined and enforced	Operational phase	[48].
			Need for a method for both CSCs and CSPs to evaluate and compare the security assurance of offered services either qualitatively or quantitatively	Operational phase	[49]
		Security assurance of multi-cloud applications	The security assurance of the multi-cloud applications is a challenging and unsolved issue.	Operational phase	[50].
		Implementation and effectiveness of security control	-To measure effectiveness of security control in operation is challenging. -A method is required which can assure whether security controls are adequate and appropriate	Operational phase	[51]
		Security monitoring and analysis	A monitoring methodology/tool is required to monitor the security	Operational phase	[52]
		Security transparency and auditing	-Lack of security transparency and auditing in cloud-based services — Existing methods do not support in achieving security transparency as per users' requirements	Operational phase	[53]

7. Security goals, requirements and metrics

The security assurance evaluation process requires specific assurance goals, security requirements, and design guidelines, which can be used by security personnel to assess and ensure a high level of security assurance. In this section, we discuss the security goals, requirements and security metrics.

7.1. Security goals

Organizations implement a security policy to impose a uniform set of rules to handle and protect the crucial information of the system. Most of these security policies consider three significant aspects of their data and information: confidentiality, integrity, and availability. However, these security requirements can be emphasized based on application domains. Most of the work primarily focused on these three security requirements in literature. However, some of the works also included other security goals for security assurance, such as privacy, authenticity, accountability, conformity, utility, possession, non-repudiation, and authorization, as shown in Table 3.

7.2. Security requirements

Adequate security assurance signifies that a software system's specified and predefined security assurance requirements have been satisfied during the security assurance assessment processes and activities. Security requirements can be categorized as functional and non-functional requirements that need to be satisfied to achieve the security attributes of a software system. The functional requirements define what the system does or must not do; it must be testable, which means the requirement can be tested to check whether it is fulfilled. Non-functional requirements define how the system should do. It considers the performance of the whole system. Security assurance requirements can be determined by analysing the security requirement of a software

Table 3
Summary of security goals considered in the literature.

Security Goals	Papers
Confidentiality	[22,40,46,48,54,55] [56,57] [58] [42] [59] [60] [53] [2] [61]
Integrity	[22,40,46,48,54,55] [56,57] [58] [42] [59] [60] [53] [2] [61] [62]
Availability	[22,40,46,48,54,55] [56,57] [58] [42] [59] [60] [53] [2] [61] [19,21] [62]
Privacy	[62]
Authenticity	[56,57] [58] [42] [59] [60] [62] [43]
Accountability	[53] [2] [61]
Conformity	[53] [19,21]
Utility	[58]
Possession	[58]
Non-Repudiation	[42] [60] [61]
Authorization	[42] [59] [43]



Fig. 6. Security requirements methods.

system, security policies, business drivers, operational environment, etc. The security requirements should be based on the iterative threat, vulnerability, and risk analysis and should also incorporate the technical and architectural information [42].

CC provides a structured method to list the security requirements that include an IT system's functional and assurance requirements. Security function requirements describe various functional requirements in terms of communication security, security audits, data protection, authentication, security management, system access, trust path, etc. System developers can select a subset of these requirements to implement in the form of security properties as a part of the security target document of the TOE. On the other hand, security assurance requirements are the requirements that need be fulfilled to assure that the security functions are implemented correctly. Security assurance requirements cover configuration management, guideline documents, delivery and operation, assurance test, vulnerability assessment, etc [63–65].

Various methods have been developed in the literature for security requirements elicitation, tracking, analysis, correctness, modelling, etc., as shown in Fig. 6. Some of these methods are:

7.2.1. Elicitation, tracing, and analysis of the security requirements

Building a secure system is complicated for several reasons, including a lack of security expertise in development teams, inadequate methodologies to support non-expert developers, etc. The security standard such as CC can be used to specify the security functional and assurance requirements, and UMLsec can be used for model-based security engineering. However, it is difficult to understand this security expertise and guidelines for the developers because it is not written explicitly. Therefore, a methodology is required for elicitation, tracking, and analysing the security requirement. Houmb et al. [32] developed such a methodology called SecReq by combining three techniques: CC, the heuristic requirements editor HeRA, and UMLsec. The SecReq is designed to make the security requirements engineering more systematic and effective by integrating elicitation, traceability, and analysis activities.

7.2.2. Security requirements modelling

Eliciting and modelling the security requirements in the development phase are well-known practices to prevent potential vulnerabilities. However, the existing methodologies such as KAOS [66], SecureTropos [67] are neither useful nor widely accepted in the industries because of mismatching in the software development process and their complexity. There is also a lack of a standard for documentation of the security properties of a software system concisely and systematically during the development process. Taguchi et al. [33] developed a framework that provides a security requirement modelling method for the system development and security assurance under the CC. This framework aligned the security requirements and assurance in a single requirement modelling methodology uniformly and concisely.

7.2.3. Correctness of the security requirements

In general, the security requirements are identified during the design phase based on the assumption made on the system operating environment. These assumptions are no longer valid if there are any changes in the system environment. On the other hand, security requirements may be adequately identified during the development phase but not correctly deployed or become less effective due to unidentified hazards in the system. Due to this, it is not easy to ensure that the secure system will remain secure over time. Therefore, an approach is needed for continuous security assurance, which also supports whether the security requirements can be fulfilled during the system operation based on the evidence collection. Ouedraogo et al. [19] developed an approach that complements security requirements engineering methodologies to check whether the security requirements elucidated during the development phase of the system have been correctly implemented by collecting continuous evidence.

7.2.4. Measurement requirements

The continuous independent evolution of the complex and operating system components makes the security measurements more challenging. In the context of security assurance, the correctness of the security controls is the main objective of the measurements. Security measurements and their different properties change over time. Therefore, the measurement framework should consider the variation in the measurement target and available measurement infrastructure. With the evolvement of the available measures, it is vital to manage the dynamic features. Kanstrén et al. [68] introduced a taxonomy-based approach and proposed an abstraction Layer between the measurements identified in the measurements framework based on the measurement infrastructure and requirements. This approach helps to relate the available and achievable measurements to the measurement requirements of security assurance plans and in managing the dynamic features in measurement requirements.

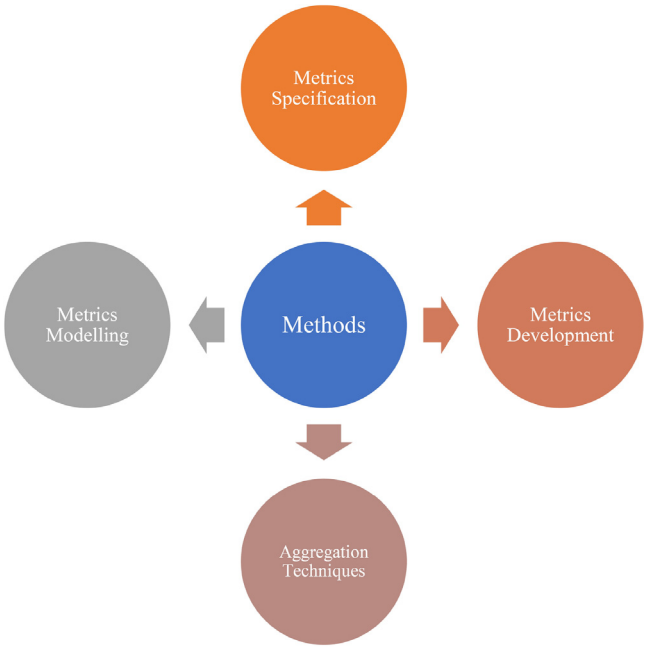


Fig. 7. Security metrics methods.



Fig. 8. Security metrics methods.

7.3. Security metrics

The dynamic nature and complexity of the security risk make it challenging to measure security as a universal property. Lack of standard definition is also one of the main reasons behind this. Metrics is the widely used and more suitable term for security-related objectives [59]. Security metrics offer security-related information from a different point of view which helps in essential and credible information security measurement of a software system. In the literature, extensive research works have been done on defining the metrics taxonomy. NIST [69] provides standards for determining the adequacy of in-place security methods, policies, and procedures using metrics. It explains how metrics can be developed and implemented and how they may be used to justify the security procedures investment.

7.3.1. Quality criteria of security metrics

The three core quality criteria of security metrics are correctness, measurability, and meaningfulness. These criteria are crucial for security metrics measurements and their practical application. To ensure the correctness of the security metrics, a well-established and systematic development methodology is required, which includes validity and reliability analysis; measurability of the security metrics can be improved by continuous development of an efficient and relevant measurement framework for the system under evaluation [70]. Moreover, the simplicity and reliability of the metrics are also essential to make the security assurance methodology more robust. It enables a fast and objective evaluation of a system's security assurance level. [71]. Several works have been done in the literature on methods and quality parameters of security metrics, as shown in Table 3, Figs. 7 and 8.

7.3.2. Security metrics management and measurement

This subsection discusses various factors and techniques for security metrics management and measurement.

(a) *Meaningfulness of Security Metrics and Measurements*
The meaningfulness of security metrics and measurements is remarkably challenging in security decision-making, such as risk management and security assurance. Because of poor management and a significant number of uncategorized data, many security metrics activities have a low level of meaningfulness. Primarily, only a limited number of metrics have been developed because they are more understandable in decision-making than a large number of metrics. However, much essential information related to security can be lost in the aggregation process of the low-level metrics. Therefore, systematic and complete security metrics management and measurement are essential. Metrics visualization facilitates the management and measurements of the security metrics to enhance the meaningfulness of the decision-making process. A visualization and modelling tool is developed by Savola and Heinonen [70] for hierarchical specification and deployment of the security metrics and their measurements. This tool helps to increase the meaningfulness of metrics in security assurance and risk management contexts by hierarchical metrics modelling. It also connects high-level security objectives with detailed measurements.

(b) *Confidence in Security Metrics Measurement*
The data collected during the system's operation helps in expressing the system's current state and validating the security metrics model. Therefore, one should have confidence in security metrics and data measurement. However, several factors can impact confidence, and trust is one of these significant factors. Kanstrén, T., & Evesti [74] discussed the impact of various properties on the confidence of the measurement data, such as trusted platform module for measurement data and infrastructure assurance, trusted monitoring base techniques, and measurement probe form factors. They also defined a set of measurement data confidence levels based on the trusted monitoring base achieved. They implemented this approach as part of a metrics visualization tool in a private cloud environment.

(c) *Security Metrics Aggregation*
An efficient and straightforward aggregation method to combine the security assurance of sub-components by considering their relationship is essential for a robust security

Table 4
Summary of security metrics category, goals, and methods.

S.N.	Category	Goals	Method/ Technique	Domain	Description	Paper
1.	Security Metrics Development	Development of security effectiveness metrics for ensuring the correctness of security controls.	Risk-Driven Security Metrics Development Methodology	IT Systems (a Push E-mail service)	In this approach, security control effectiveness is measured as part of the assurance of security control correctness at the higher level.	[59]
2.	Security Metrics Measurement, and Management	Security correctness, security effectiveness and the quality of the security verification process at runtime	Developed security assurance monitoring tool and the measurement framework	IT Systems	Authors proposed a set of metrics for the appraisal of security assurance at runtime.	[72]
		Verification of the security mechanisms at runtime	Developed a taxonomy of quality metrics	IT Systems	Authors discussed the impact of various properties on the confidence of the measurement data, such as trusted platform module for measurement data and infrastructure assurance, trusted monitoring base techniques, and measurement probe form factors.	[73]
		Specification and measurement of security metrics	Developed visualization and modelling tool	Software Systems	This tool helps to increase the meaningfulness of metrics in security assurance and risk management contexts by hierarchical metrics modelling.	[70]
		Evaluation of IT systems security assurance.	Security assurance metric and aggregation techniques	IT Systems	Authors developed a risk-based security assurance metric and aggregation technique for evaluating the systems security assurance.	[71]
		Confidence in measurement data during operational security assurance	Describes the properties of a trusted measurement base and implemented as a part of metrics visualization tool and prototyped.	Cloud computing	Authors discussed the impact of various properties on the confidence of the measurement data, such as trusted platform module for measurement data and infrastructure assurance, trusted monitoring base techniques, and measurement probe form factors.	[74]

assurance methodology. A risk-based security assurance metric and aggregation technique is proposed by Ouedraogo et al. [71] that can be combined with a methodology for evaluating the systems security assurance.

7.3.3. Security metrics model for operational security

To measure the operational security assurance of a system, it is essential to understand and express the current and anticipated security posture of the system. Security metrics modelling is a significant way to express the security status of the system [74]. The data collected during a system's operation is used to express the system's current state and validate the security metrics model.

7.3.4. Security metrics taxonomy for run-time systems

Ouedraogo et al. [38,72,73] made an effort to develop a set of metrics to evaluate the security assurance of the runtime systems. Ouedraogo et al. [73] developed metrics taxonomy based on CC and the System Security Engineering Capability Maturity Model (SSE-CMM). They represented the verification probe quality levels based on five capability maturity levels of the SSE-CMM and some of the CC families such as scope, depth, rigour, and independence of verification) capabilities as requirements to attain a defined level of quality. They also made an analysis of the mapping between different capability levels and the quality levels of the different verification metrics families, such as coverage, rigour, depth, and independence of verification. Ouedraogo et al. [38,72] also developed a method to combine the security metrics into the quantitative or qualitative indicators that are crucial in developing understanding regarding the security status of an IT system component.

A summary of security metrics category, goals, and methods is given in Table 4.

8. Security assurance methods

Security assurance involves demonstrating with evidence that a system fulfils established standard security criteria [28]. It provides the confidence that a system meets the security requirements and therefore has fewer vulnerabilities, resulting in the overall reduction of risk in using the related system. Due to the importance of security assurance, most organizations make the efforts to demonstrate the security assurance of their systems but mostly rely on less effective approaches [34]. To enhance security assurance of the systems, various methods have been developed, as shown in Fig. 9 and outlined in the upcoming subsections. A categorical representation of security assurance methods is given in Table 5. This table has categorized the security assurance methods based on the various system development phases such as governance, construction, and deployment. The governance considers policy and compliance, strategy & metrics, risk, and awareness. The construction phase considers requirements, design/modelling, and verification, and the deployment includes monitoring and management. On the other hand, various methods and techniques have been used in developing security assurance process or methodology

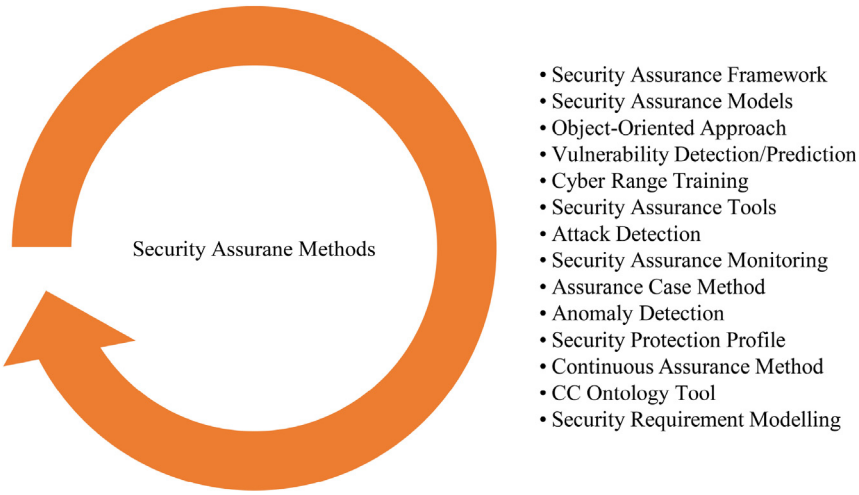


Fig. 9. Security assurance methods.

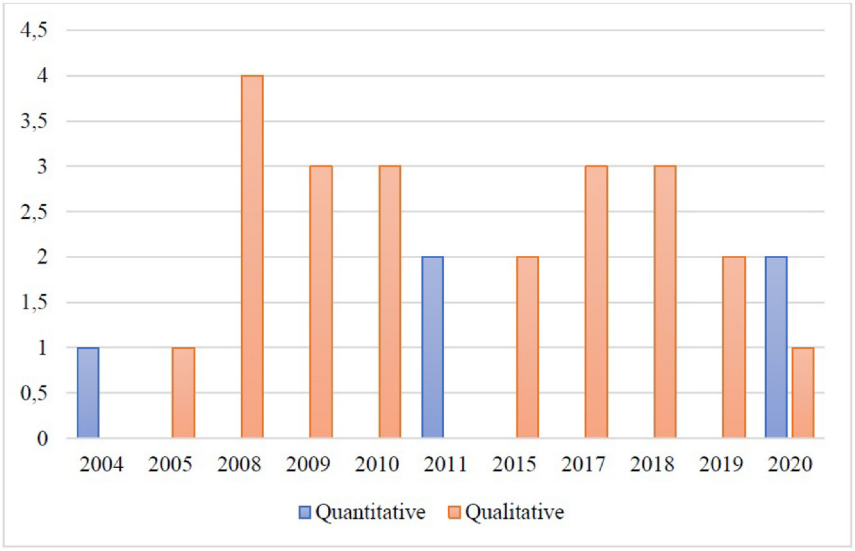


Fig. 10. Quantitative and qualitative security assurance.

A security assurance method can be classified based on its qualitative or quantitative nature. Qualitative methods use the ordinal rating scale (e.g., 1–5, low, high, critical) to represent the security level of a software system. On the other hand, quantitative methods use factual and measurable data to calculate the security level of a software system. This method is mainly based on mathematical and computational techniques. Fig. 10 represents the evolution of these two methods. This figure depicts that major of the researches have been focused on the qualitative security assurance methodology, and very few efforts have been made towards developing a quantitative security assurance methodology. Katt and Prasher [2] discussed the advantages of the quantitative security assurance method over the qualitative security assurance method. They discussed the advantages of quantitative security assurance metrics, including both positive and negative security aspects.

In the literature, various methods and techniques have been used for security assurance as shown in Fig. 11.

8.1. Security assurance framework

In the literature, the following security assurance frameworks have been proposed and discussed:

(a) Model-driven framework for security functionality verification

The major security problem for a software system is poor design practices, such as improper security functionality design and implementation in the development cycle in an improper manner. Therefore, it is crucial to verify the security functionality that is designed and developed. The codes and designs should be verified or certified by a competent authority. One of the most well-known frameworks for evaluating the security functionality of software systems is the CC framework. Deveci et al. [40] designed a framework to assist designers, testers, and analysts during the CC certification process. The proposed framework is a model-driven security framework used to analyse, design, and evaluate the security properties of information systems. This framework also supports developers and evaluation authorities in implementing the security assurance process through formal methods based on UML, object constraint language, Promela, and Spin.

(b) Quantitative security assurance framework

There are many approaches to security assurance in the literature; however, measuring the security of a software system is still a complex and tricky process. These approaches do not accurately

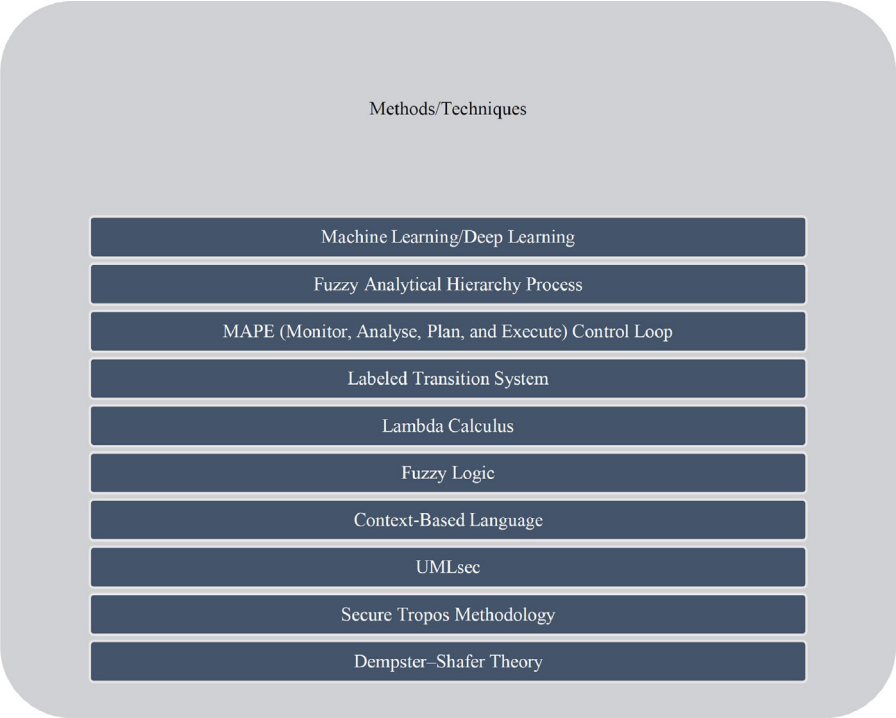


Fig. 11. Methods and techniques used for security assurance.

measure the system's security level because they either consider only one aspect of assurance, such as threats/vulnerabilities, or do not consider the significance of the various security requirements to the system under evaluation. Considering this fact, Katt and Prasher [2] developed a security assurance framework incorporating both security assurance and vulnerabilities. The proposed method is quantitative

(c) Security assurance framework for software authenticity

There is a high risk of cyber-attacks on software applications because of their popularity, misconfiguration, technical flaws, and vulnerabilities. Therefore, the software that will be installed on the critical systems must be secure. Naeem et al. [57] considered the authenticity of the software application before its installation and proposed a framework to check the authenticity of the software application before its installation. However, tools and frameworks are available, but they consider only a single aspect, such as a specific OS or a single-entry point check. The framework proposed by Naeem et al. provides a solution to overcome this challenge.

(d) Security assurance model for composed information security products

The general systems are made with different components such as servers, protocols, services, and clients. It is important to note that any weakness in one of these components may compromise the whole system. Therefore, efficient security assurance methods are required to secure these systems. The composed assurance packages (CAPs) is an evaluation method for composed security products. However, it requires analysis of potential components and interfaces between the components, which is quite difficult because of the complexity and variation in new IT products. Wu et al. [85] discussed this issue and developed a CC-based model to assess the complete network security by combining evaluation assurance levels (EAL) and CAP, where EAL is used to evaluate a single IT entity while CAP is used to evaluate the composite IT entities. Some other efforts have been made to develop component security assurance methods based on the security properties of the individual system components [26,34,35].

An overview of security assurance frameworks developed for several challenges have been given in Table 6.

8.2. Object-oriented approach

The object-oriented approach is commonly used for system analysis and design, and this has been proven over the years to be one of the most effective ways of developing systems to meet the functional requirements of users. Additionally, since security assurance involves significant evidence of the incorporation of security measures in a system, the usage of the Dempster–Shafer was used to provide such related trust. Dempster–Shafer [104] is a theory of believe functions that is used together with probability and imprecise theories of probabilities for assessing uncertainties. The combined approach in the evaluation model makes the evaluation process of security assurance clearer and makes the results to be more believable.

Cuihua and Jiajun [90] proposed an object-oriented security evaluation model using the concept of object-oriented technology. The study was motivated by the lack of effective and efficient security models. Existing evaluation models such as qualitative, quantitative, or combined approaches have not provided the necessary security evaluation model. For instance, the quantitative approach cannot obtain precise numerical results. Similarly, the qualitative approach is not objective, and both qualitative and quantitative approach requires significant improvement. To this end, the object-oriented approach and Dempster–Shafer evidence were explored for the security evaluation model by Cuihua and Jiajun [90]. They developed a security level distinguishing model using Dempster–Shafer evidence theory to combine experts' and auto evaluations, thereby making the evaluation process clearer and reliable.

Table 5
Security assurance methods in system development phases.

System Development	Governance	Policy and Compliance	Access Control Policy [47]	
		Strategy & Metrics	Security Preference [75], Assurance Profile [37,76], Protection Profile [41,77], Security Metrics [37,38,49,59,70–75]	
		Risk	Risk Assessment [72,78], Risk Management [70], Risk Model [79]	
		Awareness	Security Awareness Programme [80], Cyber Range Training [80]	
	Construction	Requirements	Elicitation [2,32], Specification [2,81], Identification [2,82], Aggregation [2,36], Measurement [2,68], Prioritization [81], Modelling [2,33,34,83], Correctness [19], Tracing [32], Security Requirements Engineering Process [29], Requirement Representation [30,52] Ontological Mapping [30]	
		Design/Modelling	Security Modelling [19,26,34,40,43,45,46,54,82,84,85], Vulnerability Prediction Modelling [44], Security Assurance Model [45,86], Security Assurance Development Process Model [87], Assurance Modelling of System Component [18,34], Model-Driven Security Framework [40,43], Network Security Assurance [88], Security Assurance Framework [2,89], CC-Based Model for Network Security [85], Framework for Authenticity [57], Object-Oriented Security Assurance Model [90], Component Security Assurance [26,34,35,85], Useable-Security Assurance [61], Service-Oriented Security Assurance [26], Formal Method [91,92], Security Assurance in Open Infrastructure [21], Other Security Assurance Methods [22,27,47,49,53,55,60,75,93,94]	
		Verification	Code Review	Vulnerability Detection Method [95–97], Vulnerability Prediction [44]
			Security Testing [42]	Penetration Testing [2,98], Vulnerability Testing [2,57,78,99], Black Box Testing [99,100], Unit Testing [100], Code Inspection [100], Security Requirement Testing [2,81]
			Threat Assessment	Threat Analysis [78], Threat Modelling [2,82,84,98]
			Security Assessment	System Modelling, Vulnerability Analysis [42,59] Interview [101]
			Security Review [87]	
			Quality of Security verification [72]	
	Deployment	Monitoring and Management	Monitoring and Auditing [21,26,102,103], Anomaly Detection [88]	
			Assurance Management, Security Durability [23]	
			Vulnerability Management [2,44,57,78,95–97,99]	

Table 6
A summary of security assurance frameworks.

S.N.	Challenges	Solutions	Framework	Domain	Paper
1.	Improper security functionality design and implementation	Verification or certification of codes and designs	Model-driven security framework to analyse, design, and evaluate the security properties of information systems.	Software Systems	[40]
2.	Inaccuracy in quantitative security assurance measurement	Development of security assurance framework considering various security requirements, threats, and vulnerabilities	A quantitative security assurance framework incorporating both security assurance and vulnerabilities.	IT and CPS	[2]
3.	Authenticity of the software application before installation	Check and ensure the authenticity of the software application before installation.	Framework for checking the authenticity or credibility of applications or software	Applications or software	[57]
4.	Security assurance of composed information security products	Security assurance method by analysis of potential components and interfaces between the components	CC-based model to assess the complete network security by combining evaluation assurance levels EAL and CAP	Composed Information Security Products	[26,34,35]

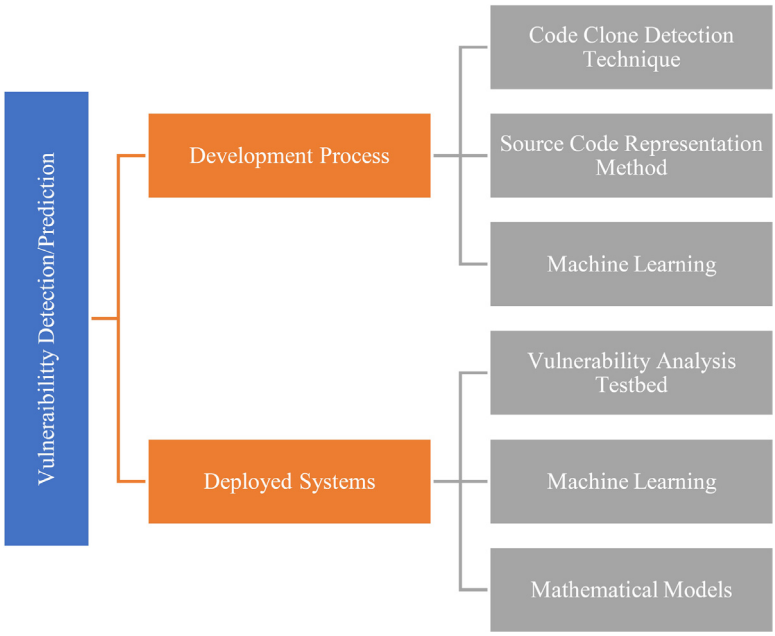


Fig. 12. Vulnerability detection/prediction methods.

8.3. Security assurance development process model

Security is an important feature that needs to be considered during the software development lifecycle (SDLC). A secure SDLC involves integrating security testing and assurance methodology and related activities in the development process. It includes different activities such as security requirements, architectural risk analysis during the design phase, threat modelling, etc. Khan and Khan [45] made an effort to study the state-of-the-art of security issues, challenges, and practices during SDLC in the industries. Based on this study, they developed a software security assurance model to assist software developer's vendor organizations in measuring their readiness to develop secure software.

The standard SDLC, OWASP's Comprehensive, Lightweight Application Security Process (CLASP), and Microsoft's security enhancement software development lifecycle (MDL) are not fit for fast-changing commercial requirements to include security assurance measures in operating systems. As a result, Lan and Han [87] developed security assurance development process (SADP) model. The model consists of an institute security awareness programme, documentation of security-relevant requirements, application of security principles to design, performing source code level review, implementing and performing security tests, security review, and risk management. The activities of SADP can be repeatedly implemented. SADP is proven to be efficient and effective and was hence adopted by NeoKylin operating system.

8.4. Vulnerability detection/prediction approach

Vulnerability is a weakness in an information software, internal controls, security procedures, or implementation that can lead to unauthorized access when exploited. Security vulnerability can cause substantial economic and reputational damage to both users and organizations. In the context of software development, vulnerabilities can be introduced in the developed system. Appropriate assurance measures are required to be taken during the development process to avoid the related risks. Therefore, identifying security vulnerabilities in the initial phases of the software development steps is paramount. However, detecting software vulnerabilities is a pretty complex process.

In the past, some efforts have been made towards identifying and predicting the vulnerabilities, such as Akram and Luo [95] developed a quantitative vulnerability detection technique at the source code level based on code clone detection technique. They retrieved vulnerable source code files from the various web source code repositories by tracking the patch file of vulnerabilities. Then, using common vulnerabilities and exposures (CVE) numbers, the vulnerable source code files are retrieved. Dissanayaka et al. [96] developed a vulnerability analysis testbed using Linux containers. The authors discussed that the developed virtual testbed is portable and easy to deploy. Hovseopyan et al. [44] conducted a study by comparing the vulnerability predictions using old and new versions of Chrome and Firefox to determine whether it is better to rely on older versions or newer versions in exploring the vulnerabilities. The study findings suggest that the vulnerability prediction based on the older versions of software tends to be reliable and establish security assurance in that regard. Vulnerability prediction models are one of the possible methods to identify the location of source code that need more attention [44].

In the literature, machine learning methods are also applied to code complexities, code churn, token frequency, developer activities, etc., to detect vulnerabilities towards enhancing security assurance. Bilgin et al. [97] used the machine learning technique to predict the vulnerability of the software from source code before its release. This work also includes developing a source code representation method, intelligently analysing the abstract syntax tree (AST) form of the source code, and then verifying whether ML can be applied to distinguish between vulnerable and non-vulnerable code fragments. The vulnerability detection and prediction methods in the development process and on the deployed systems is shown in Fig. 12.

8.5. Model-driven Cyber Range training

The increasing demand for security in organizations emphasized the need for security-aware employees in every role of an organization. Therefore, organizations need to train their employees to face potential security challenges and respond accordingly to protect their critical assets. Cyber Range training provides a

promising approach that offers employees training in realistic environments considering different scenarios and hands-on experience based on their responsibilities and expertise level. Cybersecurity training should be designed based on the organization's requirements and should adjust to changes in environments and scenarios. Somarakis et al. [105] studied the importance of dynamic and up-to-date training for cyber security. They proposed a model-driven approach for Cyber Range training, which helps to generate tailor-made training scenarios based on the organization's requirements and security posture. This approach also provides the automated deployment of training environments (see Table 7).

8.6. Useable-security assessment

The useable security software service may be subject to different security attributes such as confidentiality, integrity, availability, accountability and non-repudiation, and usability attributes such as effectiveness, efficiency, satisfaction and user error protection. These attributes are crucial in the security assurance of the software systems and will help to increase the efficiency and accuracy in security assurance measurement. Agrawal et al. [61] used the Fuzzy Analytical Hierarchy Process (Fuzzy-AHP) methodology to evaluate useable security. They also assessed the impact of security on usability and the impact of usability on security using a quantitative approach.

8.7. Security assurance tools

Security assurance tool supports measurement of real-time security assurance level and to maintain the security of complex and large-networked operational systems in automated way. Pham et al. [36,39] discussed the need of security assurance tool to measure the assurance level of the deployed system. Some authors also made efforts towards the development of tool to support security assurance evaluation process.

CC certification is a complex and time taken process that demotivates industries to adopt this process. Ekclhart et al. [30] developed CC ontology tool to ease the CC certification process. This tool is based on ontological representation of CC catalogue and supports various tasks such as evaluation process planning, making reports and review of the applicable documents. Savola and Heinonen [70] developed a tool for visualization and modelling the hierarchical specification and deployment of security metrics and measurements. This tool also supports security decision making by managing a large number of metrics and measurements in an efficient way.

8.8. CC ontology tool

The certification process of information security products and systems using CC is very complex and time-consuming. This has discouraged several organizations from the CC certification process. To address this issue, Ekclhart et al. [30] developed a CC ontology tool based on an ontological representation of the CC catalogue. The developed tool supports the planning of an evaluation process, reviewing the relevant documents, and creating the reports. These features simplify the CC certification process and can facilitate the adoption of CC certification by more organizations. However, the developed tool is mainly designed for security assurance requirements relevant for the evaluation.

9. System and environments

The recent advancements in security assurance suggest a promising approach to ensure the security of software. The security assurance of the system depends on both static and dynamic security metrics. The static metrics of the system change when there are changes in configuration or a component is added or removed. Whereas the dynamic metrics change over time [39]. However, most of the existing works focus on the static vision on the description of the system under evaluation and do not consider the system's dynamic behaviour. For example, the CC is a static process that relies on the accredited security experts. The main disadvantage of this procedure is that it is ad-hoc in the laboratory for a single product, and it loses significance when a certified product is brought into an operational system or modified. Implementation of operational security assurance in large dynamic systems is a challenging task. Moreover, providing continuous security assurance evaluation and implementing countermeasures to achieve the security goals is also a complex task [37]. Fig. 13 represents the evolution of static and dynamic security assurance evaluation methods. This figure shows that most research works have considered static security assurance, whereas very little research has been done on evaluation of dynamic security.

The development of the security assurance method of a software system needed the definition and a clear understanding of the security requirements of the concerned application domain. Many researchers proposed the general security assurance methodology, while others developed the application-oriented approaches. As per our observation, in some application domains, pervasive research works have been done, such as cloud computing, telecommunication, etc. while in some of them, there are very limited research works such as railway, e-governance, etc. The overview of the application domains in which the research works related to security assurance have been shown in Fig. 14. The application domains are categorized mainly into two categories: CPS and IT systems. Since cloud is quite a popular application domain and many research works have been done. Therefore, we will discuss the challenges and methods of cloud security assurance separately.

9.1. Security assurance in access control

Access control is one of the important measures in security assurance and crucial to ensure that information is secured, uncorrupted, and available in the application. A system should have the assurance that the resources access by the users are authorized and authenticated. The different types of access control include role-based and attribute-based [107]. Therefore, the incorporation of access control needs to be considered in the initial stages of the system development process.

It can be a challenging task to incorporate the access control into the software if most of the requirements related to the access control are identified and implemented after the functional requirements [108]. Accordingly, access control requirements are mostly considered after the functional requirement definition stage, leading to flaws and security defects in the access control mechanism. Therefore, a security assurance mechanism is required to ensure that the application code behaves consistently with the access control policy [47]. A framework developed by Pavlich-Mariscal et al. [47] showed that the access control requirements that were identified and designed have been correctly implemented at the code level. A labelled transition system (LTS) was used at the design stage to represent the behaviour of the system. Lambda-calculus was used at the code level to capture the essential features of the access control

Table 7
Security assurance methods.

S.N.	Security Assurance Methods	Challenges Considered	Contribution	Application Domain	Paper
1.	Object-Oriented Approach	The existing quantitative and qualitative security methods are not efficient.	Proposed an object-oriented model for a clear security evaluation process structure.	Information Systems	[90]
2.	Security Assurance Model	Development of secure software	Developed software security assurance model to assist vendor organizations in measuring their readiness towards the development of secure software	Software Development	[45]
		Current security assurance methods are not capable to evaluate the entire development process and not applicable for different projects	Developed an easy-to-implement and easy-to-evaluate Security Assurance Development Process (SADP)	Software Development	[87]
3.	Vulnerability Detection/ Prediction Approach	Auditing source code for vulnerabilities at a large scale	Developed a vulnerability detection method to detect vulnerabilities in software and shared libraries at the source code level	Software	[95]
		A model or testbed for assessing vulnerabilities that is deployable, maintainable, and accurate	Developed a general vulnerability assessment testbed that is portable, virtual, and deployable	Software system	[96]
		To predict software vulnerabilities from source code	Developed a source code representation method and applied machine learning methods to identify vulnerable code fragments	Software	[97]
4.	Cyber Range Training	A cyber security programme should be tailored to the needs of the organization and should be able to adapt to the rapidly changing environment easily	Created a model-driven approach for Cyber Range training based on a comprehensive description of the organization's security posture that facilitates the generation of tailor-made training scenarios	Multi domains including smart home, healthcare, smart shipping environments	[105]
5.	Security Assurance Tools	The need for a tool to determine a system's security assurance level	Provides a tool for determining the level of security assurance of network systems in near real time	Software systems	[36,39]
		Need for a tool to assist the evaluator during the CC certification process.	Developed a tool to represent the CC catalogue ontologically	IT products and systems	[30]
		The need for an efficient tool to determine a system security	Created a visualization and modelling tool for managing security metrics and measurements in software-intensive systems	Software-intensive systems	[70]
6.	Attack detection Method	To improve the speed and accuracy of attack detection	Implemented machine learning and deep learning techniques on the core of the operating system	Manufacturing industry	[27]
7.	Security assurance monitoring	Continuous monitoring of telecommunication services is paramount	Demonstrated the applicability of a security assurance methodology for telecommunication infrastructure (BUGYO) on a VoIP infrastructure.	Telecommunication service	[21]
8.	Designing Security Assurance Framework	Assuring the security, privacy, and safety of the handled data.	Conceptually aligning EBIOS, Secure Tropos, and PRIS methods to create a complete assurance framework	Intelligent Transport Systems	[89]
9.	Anomaly detection method	Monitoring and analysing network security to identify suspicious activity throughout the network	Discussed the available methods and tools and presented a general concept of security analysis component for the security operational centre.	Network Traffic	[88]
10.	Assurance case method	The adaptation of existing assurance case methodologies to cover specific IIoT issues	Presented a framework for assurance cases for IIoT and security cases that included elements of properties assurance, security management assurance, component assurance, and feature assurance.	Industrial IoT	[60]
11.	Continuous assurance methods	To assess the security of IoT systems continuously, a systematic approach is required	Developed a conceptual framework for IoT security assurance evaluation and presented a process for developing continuous assurance methods for IoT services.	IoT	[22]
12.	Model-Driven Security Assurance Framework	Security assurance needs to be automated	Proposed a model-driven framework to allow designers to model security concerns and to facilitate automated verifications and validations.	Open-source software	[43]

(*continued on next page*)

Table 7 (*continued*).

S.N.	Security Assurance Methods	Challenges Considered	Contribution	Application Domain	Paper
13.	Security assessment system	Secure deployment of WLAN network	Developed a fuzzy logic-based security assessment system	WLANs	[106]
14.	E-government security assurance system	Constructing safe, reliable and effective e-government security assurance	Developed a reference model for the security assurance of e-government systems	E-governance	[86]
		To educate personnel working in E-Government systems about cyber security assessment	Created a framework for assessing information security issues in e-government	E-governance	[80]
15.	Security Protection Profile	Railway automation does not have any harmonized IT security requirements	Describes a reference communication architecture which attempts to separate risk management and security requirements as well as certification processes as far as possible, and outlines the threats and IT security objectives with typical railway assumptions.	Railway Automation	[77]

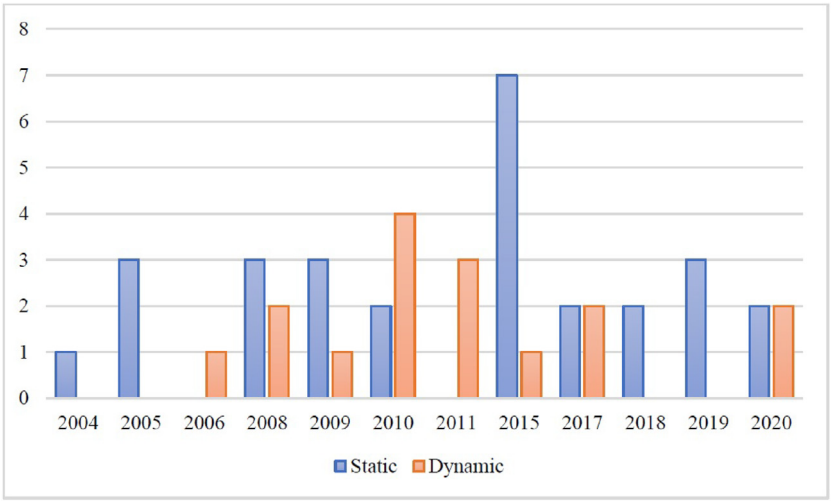


Fig. 13. Static and dynamic security assurance methods.

requirements. The requirements were then mapped from the LTS to the lambda-calculus as a representation of the correct representation of design to the code. The work was validated by applying the framework to two access control mechanisms.

9.2. Security assurance of the self-adaptive system

The trustworthiness of the self-adaptive system is the primary concern. The dynamic environment of these systems makes security goals challenging to achieve. These systems must manage uncertainty due to the dynamic environments, functional changes and malicious attacks and fulfil their security requirements in the deployed environment and as if there are any changes over time. Therefore, security assurance of these systems is required to maintain the system's trustworthiness within the uncertainty. The security assurance of these systems becomes even more critical when they are used in business-critical and safety-critical applications. Therefore, an efficient method is required to assure confidence in the security profile of self-adaptive systems, which adopts the changes in functional and security conditions at runtime. However, it is a challenging task due to the complexity of the security dependencies. To manage the security concern, the self-adaptive system should consider MAPE (Monitor, Analyse, Plan, and Execute) control loop [109]. In this regard, Jahan et al. [102] developed a security-focused feedback control loop, MAPE-SAC, and its interaction with a MAPE-K, function, and performance-focused control loop to dynamically manage runtime adaptations in response to changes in functional and security conditions.

9.3. Core-level cybersecurity assurance

Sakthivel et al. [27] studied the core-level cybersecurity assurance. They considered the core of the operating system than the application level service for their study to increase the speed and effectiveness in attack detection. The main advantage of considering the operating system's core is that it contains every internal attribute and the file system. They implemented the machine learning and deep learning approach and found that classification and learning methods used in different machine learning techniques can enhance the protection of the systems against potential attacks.

9.4. Security assurance of telecommunication system

Telecommunication infrastructure experiences continuous and increasing security threats and risks. There is a need for the deployment of adequately tested and managed information security solutions. The security assurance of the telecommunication system can help to fulfil this requirement. Software security assurance incorporates different methods such as security testing, security analysis, security monitoring, security auditing, etc.

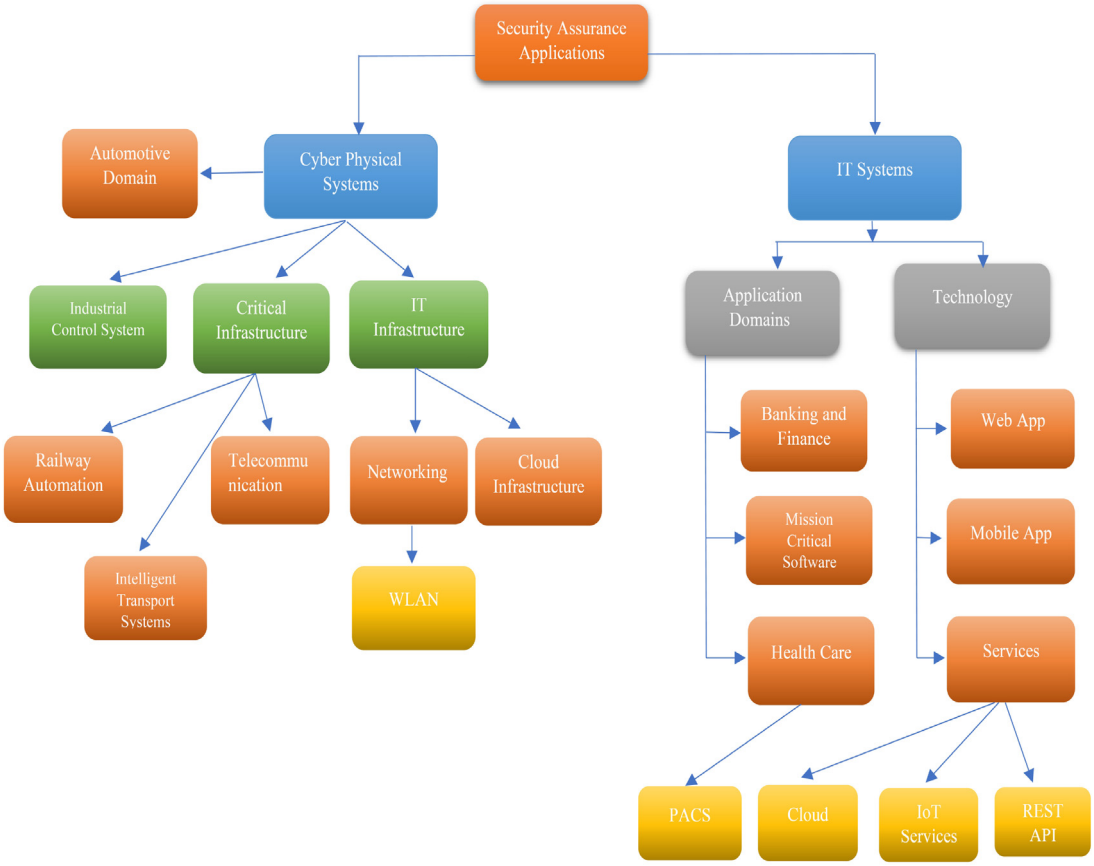


Fig. 14. Application domains of system security assurance.

Security testing is an essential process in security assurance, and it should be implemented iteratively on analytical and practical stages [42]. On the other hand, continuous monitoring of telecommunication services is paramount to get the quality assurance of the services being provided. Ouedraogo et al. [21] discussed the applicability of the BUGYO (Building Security Assurance in Open Infrastructures) methodology on VoIP service infrastructure based on open source components. BUGYO is a CC-based methodology that addresses the security assurance issues related to the telecommunication infrastructure and services and verifies that the services provided through the infrastructure are secured.

9.5. Security durability of web application

Kumar et al. [23] focused on optimizing the security assurance effort for a specific lifespan of a web application by estimating its security durability. They identified three factors: trustworthiness, dependability, and human trust, which can improve security durability. They estimated the security durability quantitatively by using a Hesitant Fuzzy based Analytic Hierarchy Process and Technique for Order of Preference by Similarity to Ideal Solution hybrid technique.

9.6. Security assurance framework for intelligent transport system

The growing number of vehicles on the road is one of the significant causes of road traffic accidents, a major public safety problem. The emerging model of connected vehicles enables a significant technology shift in improving road safety and fostering the emergence of next-generation cooperative intelligent transport systems (ITS). Networked ICT, internet of things (IoT), and CPS help the ITS enable services and applications such as communication of vehicles with nearby vehicles and roadside infrastructures, etc. However, these technologies come with several challenges, including security and privacy. The wireless connection of these vehicles to external entities can expose the ITS applications to various security threats and attacks. Therefore, it is essential to consider these concerns while developing the ITS. Diamantopoulou et al. [89] developed a security assurance framework for connected vehicular technology.

9.7. Security assurance of network traffic

With the rapid growth of organization intranets, network traffic security has become a more complex task for network security administrators. The incorporation of emerging technologies such as cloud computing and IoT is also increasing the attack surface. Therefore, it is vital to monitor and analyse the network security to identify suspicious activities throughout the network and mitigate it. The security analysis process includes the intercepting, recording, and analysis of the pattern of network traffic communication. The implementation of security measures in a particular organization is incomplete without these processes. Bialas [88] considered one of the main concerns of network security assurance, i.e., anomaly detection in network traffic monitoring and developed an anomaly detection component.

9.8. Security assurance of IoT devices

Present-day, IoT has become one of the unprecedented research topics in cybersecurity research. IoT is a system that enables computing devices, mechanical and digital machines, objects, things, and animals in our environment to interconnect

with each other over the internet without the need for human-to-human or human-to-computer interaction. Embedded sensors and unique identifiers allow smart things to interact with each other over the internet; and create smart applications and services such as smart cities, smart homes, smart schools, smart healthcare smart cars, intelligent transportation, smart grid, etc. IoT provides real work intelligent platform for distributed object interaction through various communication technologies. It made IoT systems an attractive target for attackers and adversaries interested in stealing sensitive information. Therefore, a systematic method is needed to assess the security of IoT systems. Ardagnan et al. [22] developed continuous assurance methods for IoT services and designed a conceptual framework for IoT security assurance assessment. Sklyar and Kharchenko [60] proposed a framework to utilize Assurance Case methodology for Industrial IoT systems (IIoT).

9.9. Security assurance framework for OSS

Open source technology is a growing trend in a wide range of applications. There is a great demand for open source technology in most modern enterprises. However, it comes with great concern over the security assurance provided by open source components. Frequent updates are required to fine-tune the product and to improve its performance. These updates add new features and improve or remove old features in the software; this can violate the security properties designed for the previous versions. Therefore, a systematic and efficient security assurance technique is required to measure the security level of open sources software and its released versions in an automated way. When open source software (OSS) is combined with the REST architectural style, this task becomes more challenging. REST architecture has several additional scalability and extensibility benefits, which help to add more features and offer the services to a larger audience. Design methodologies and mechanisms are required to use the REST APIs that manage stateless protocol for stateful applications. Rauf and Troubitsyna [43] proposed a model-driven framework that will help designers to model the security concerns of REST compliant open-source software and to enable automated verification and validation. It also facilitates a regular monitoring mechanism of the security features, even considering frequent updates of OSS.

9.10. Wireless Local Area Networks (WLANs)

Wireless networking is quite popular and one of the rapid growing technologies. A WLAN is a network that enables devices' capability to connect and communicate wirelessly for homes and businesses. However, while it provides convenience and flexibility, secure deployment is not always possible and is still a primary concern for researchers and developers. Liu and Jin [106] conducted a study to analyse the security threats and attacks to the WLAN network architecture and developed a security assessment and enhancement system. This system is divided into two subsystems, a security assessment system and a security enhancement system. The security assessment system is based on fuzzy logic and analyzes vulnerability of physical layer (PHY) and medium access control (MAC) layer, key management layer and identity authentication layer. This approach provides quantitative value of security level based on security indexes. Whereas the security enhancement system is an integrated, trusted WLAN framework based on the trusted network connect that helps to improve the security level of WLAN.

9.11. Security assurance of E-governance

E-government can be defined as the use of information and communication technologies in delivering government services across the citizens, various public service agencies and businesses, and the management of these services effectively and efficiently. E-government helps the government to reduce operational costs by better-integrated workflows and processes and effective utilization of resources. However, e-governance comes with several challenges, among which information security is the more serious. Therefore, the government should take the necessary measures and actions to secure useful information such as government data and citizens' data to guarantee national security. The security assurance of E-governance can guarantee the operation of the e-government system in a secure, reliable, and effective way. Lixiang [86] discussed the security issue of Chinese E-governance and proposed a reference model for information security assurance. Gupta et al. [80] conducted a study to educate the person working in the E-governance system. In this regard, they suggested a framework considering various internal and external features of an organization's security.

9.12. Protection profile in railway automation

Railway automation has experienced increasing IT security incidents in recent years. However, most of these attacks are denial of service attacks to target interruptions of services, not related to any safety-critical incidents. Therefore, IT security requirements for railway automation is needed. Bock et al. [77] discussed this issue and represented the CC-based IT security requirements for the railway domain as a protection profile. They also developed a reference architecture to distinguish IT security and safety requirements and discussed security objectives and threats in this application domain.

9.13. Cloud security assurance

Cloud computing is a computing paradigm that has transformed the service deployment landscape of ICT. It offers various on-demand, highly available, scalable, and ubiquitous services that extend beyond the geographical and administrative boundaries, thereby attracting organizations to deploy their services in the cloud. However, cloud services come with security concerns due to many users. The externalization process of the application is also one of the main reasons to increase its potential surface of attack. The lingering concern of security concerns is one of the main reasons organizations resist the cloud. Thus, cloud security became the major concern for both researchers and industries. The challenges face by CSCs, CSPs and common issues are illustrated in Fig. 15. The overview of assurance methods and techniques developed in the literature are as follows:

9.13.1. Enforcement of security properties in cloud

Enforcement of the security properties in the cloud is an essential and challenging task. It is important to assure that the essential security requirements have been effectively enforced. The assurance properties can be helpful to verify the effective enforcement of the security requirements and provide evidence of the enforcement. Bobelin et al. [52] proposed a context-based language to express the assurance properties based on the security requirements. The property prototypes are used to represent the security requirements. These prototypes are high-level definitions of security requirements that can address one of the major issues, i.e., difficulty in defining the security policy.

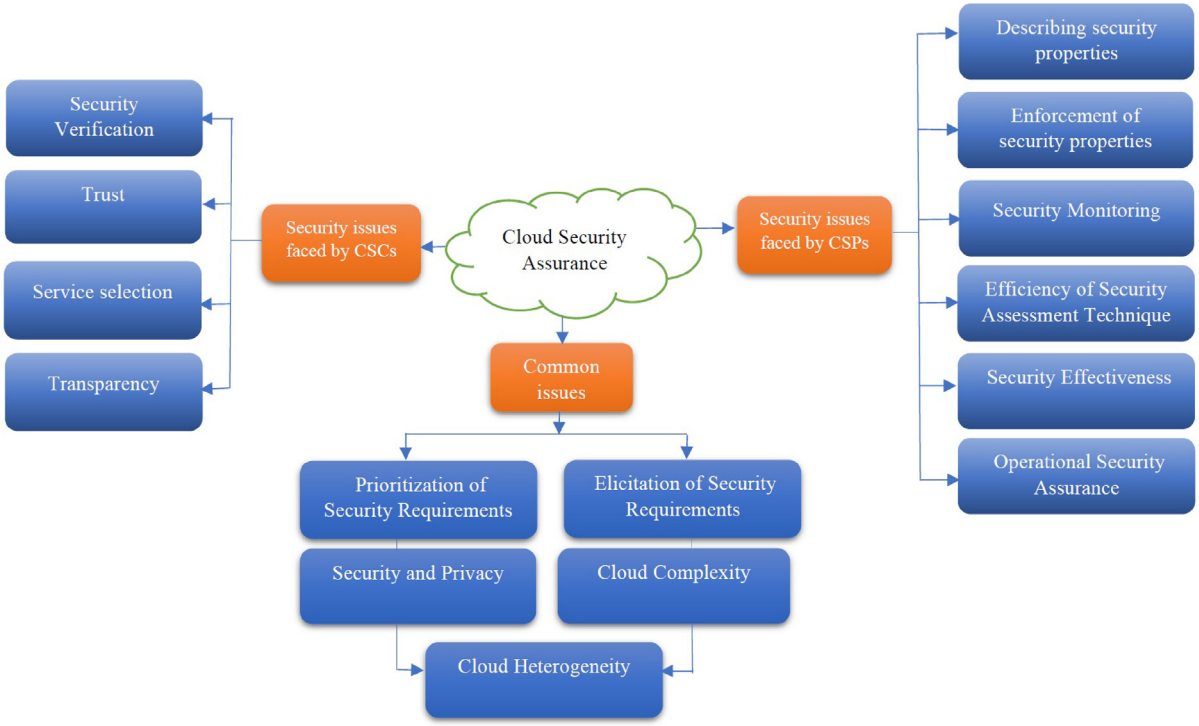


Fig. 15. Security issues related to cloud security assurance.

9.13.2. Security assessment of cloud considering CSPs and CSCs requirements

Cloud computing provides multiple benefits to users. However, CSPs should provide trust to CSCs with their data and ensure data integrity and confidentiality. On the other hand, CSCs should know what security assurance CSPs are offering and should compare the CSPs offers qualitatively or qualitatively based on their requirements. The formalization of the security properties CSPs offer is the first step in assessing and comparing CSPs. Cloud community is working to develop a standard specification of security service level agreements (SecSLAs) that can help CSPs to ensure the desired level of security to CSCs for their services [93].

Modic et al. [49] developed a cloud security assessment technique, i.e., moving intervals process. This method supports multiple requests in parallel, and it also considers variation in the number of CSPs and the security requirements of CSCs. The proposed technique offers high computational efficiency as well as accuracy. They also developed an approach to quantify the security attributes considered in SecSLAs to compare different SecSLAs offered by CSPs. Rizvi et al. [75] also considered the decision-making problem of CSCs in the selection of available cloud services based on their security strength. They proposed a framework and mechanism that can assess the robustness of CSP security based on customer security preferences. They developed security evaluation rules for security metric based on linear equations. This rule helps cloud service users analyse the security index scores of one or more CSPs and verify the final security scores.

9.14. Continuous security assessment for security certification of cloud

Cloud services need continuous refinements and requirements changes, which affects the security and resilience posture of the service and invalidates the certificate. In this situation, recertificate may be needed, which leads to high costs. These drawbacks demotivate the CSPs that intend to leverage the advantages of the cloud.

In the last decades, several methods have been developed for systematic and comprehensive cloud security to address this shortcoming. One of the drawbacks of these approaches is that they can reveal a cloud service provider's intellectual property as part of the assessment process. Aggregation of assessment results into the assurance levels can be one of the possible methods to address this problem, which is used in CC [110]. CC assurance levels show the sophistication level of tests performed on a system, such as functional, structural, methodical, semi-formal, and formal. Hudic et al. [55] made an effort to develop a security assessment methodology for security certification, which provides continuous security assessment and also protects the cloud provider's intellectual property.

9.14.1. Security transparency and audit

Security transparency and audit are essential factors that the industries must consider to increase the users' trust by fulfilling the requirement of the offering services. Security transparency increases assurance and accountability by providing essential information to the customers about the security practices and procedures. Whereas, security auditing is the tracking and collecting evidence of the significant events in the operational phase of the system, which is useful to achieve the overall goal security objectives of the system. Ismail and Islam [53] discussed these two factors and developed a framework to address challenges regarding security transparency of the cloud. They have also developed a Security transparency and audit tool that can help auditors to evaluate the evidence produced by the CSP.

9.14.2. Enforcement and monitoring the SecSLAs

The establishment of SecSLAs is not enough to fulfil the requirements of CSPs and CSCs when there is a lack of management in SecSLAs commitments. A systematic mechanism is required for CSPs to take action against the eventualities such as attacks, changes, disasters, or regulations that may affect the fulfilment of

Table 8
A summary of cloud security assurance methods.

S.N.	Category	Challenges	Proposed Solution	Paper
1.	Security assurance of cloud services	Standard specification of security service level agreements	- Developed a cloud security assessment technique -Developed an approach to quantify the security attributes considered in SecSLAs	[49]
			Proposed a framework and mechanism that can assess the robustness of CSP security based on customer security preferences	[75]
2.	Enforcement of the security properties	Effective enforcement of security properties in the cloud	Proposed a context-based language to express the assurance properties based on the security requirements	[52]
3.	Security Certification of Cloud	Continuous refinements and requirements changes may invalidate the cloud certificate	Develop a security assessment methodology for security certification	[55]
4.	Security transparency and audit	Implementing security transparency and audit	-Developed a framework to address challenges regarding security transparency of the cloud -Developed a security transparency and audit tool	[53]
5.	Enforcement and Monitoring the SecSLAs	A systematic mechanism is required for CSPs to take action against the eventualities such as attacks, changes, disasters, or regulations	Proposed a solution for monitoring and enforcing SecSLA compliance.	[103]

the SecSLA commitment. The efficient detection and mitigation of potential threats or harmful security-related events are essential for CSPs to provide trustworthy services to CSCs and fulfil and maintain the agreed assurance levels. For example, if an attacker cracks the encryption key, there is no automated mechanism to indicate that there may be a security breach and the protected information is exposed. Trapeiro et al. [103] proposed a solution for monitoring and enforcing SecSLA compliance.

A summary of cloud security assurance methods has been given in Table 8.

10. Limitations and future research directions

The rapid evolution of technology comes with security concerns and lends the information technology environment to potential uncertainty. Therefore, security solutions must be advanced to prevent potential threats and risks before and when they occur. The current security assurance methods are good at flagging the anomalies but not too good at defining their impact and potential risks. These are some limitations of the existing security solutions and future challenges:

10.1. Security requirements analysis

CC provides organized and concrete guidelines for evaluation. CC sets the possible security requirements that include assurance requirements and functional requirements. However, the elucidation of the structural relationship between security requirements and security assurance requirements and their evaluation is a possible future research direction [33].

10.2. Enforcement of security requirements

The security requirements are developed to meet the need of consumers, developers, and evaluators. To achieve a particular EAL, a set of activities including all security requirements needs to be identified and evaluate these security requirements against the user's requirement and eliciting new requirements based on the objectives to be met. However, CC does not offer a well-defined methodology to employ the enforced requirements.

10.3. Correctness, quality and effectiveness of the security assurance

Security assurance provides confidence that system assets are protected; however, this confidence depends on the correctness of the security measures, quality of the security policy, and profile of the attackers [19]. The effectiveness of the assurance techniques is another factor that is difficult to measure in the operational phase. A methodology is required to measure that the security controls are adequate and appropriate for specific systems. Therefore, it is essential to consider these factors while developing a security assurance method.

10.4. Real-time security assurance evaluation

In most of the existing works related to security assurance evaluation, the system's dynamic behaviour under evaluation has not been considered. These works mainly focused on static behaviour. Therefore, a method/tool is required to measure and verify the security assurance level of the system in real-time. This method will be helpful to maintain and improve system security on a day-to-day basis in the operational phase.

10.5. Automation of security assurance process

Automation of security analysis, evaluation, validation, and testing approaches is required to obtain continuous evidence about a system's security assurance level or performance under evaluation. There are no widely accepted methods or approaches that fulfil this requirement.

An automated security verification technique for web applications is also crucial. The current technology, such as network firewalls and antivirus, offers security protections only at host or network levels. Therefore, one should also focus on security at the application level, i.e., the publication interfaces of web applications which is a more attractive target. In the past, white-box and black-box testing frameworks have been used for automated web applications security assessment. However, one of the significant drawbacks of black-box testing is that it requires source code which is not available in many cases, and the second is that the verification process runs on simulated runtime behaviours based on programme abstraction, while the abstraction may not reflects the actual programme correctly. On the other hand, black-box testing framework work also comes with several challenges, such as providing an efficient interface mechanism [99].

10.6. Security assurance tool

Security assurance tools help developers in building secure systems and to measure how secure system is. There is no efficient tool available that supports real-time security assurance of the system in an automated way. Therefore, there a need is to improve the security assurance tools and develop new tools that can help in security assurance evaluation of large networked IT systems.

10.7. Security assurance of composed system

Direct measurement of security assurance for complex software systems is not always possible. In this case, one of the possible methods is to decompose the system into measurable parts and measure the assurance of decomposed entities. However, in this method, aggregation is required as a backward process to obtain the security assurance of the software system by aggregating the security assurance values. Therefore, a suitable aggregation technique is required. The method should consider the composing entities that are security assurance relevant and relations between the components. It is also essential to understand how constituent components of a system under evaluation contribute to the system's security [36]. Defining and developing confidence metrics for security assurance level and the selection and aggregation technique for these security metrics is another future direction.

10.8. Quantitative security assurance approach

In the past, very few efforts have been made to develop a systematic approach to quantify the security to support security assurance activities. Most of the approaches are focused on qualitative security assurance. There are no standards or widely accepted methods, models, taxonomy, or tools for quantitative security assurance. The advantages of the quantitative security assurance approach have already been discussed in the previous section.

10.9. Competencies of individuals

Individuals performance assessment and verification are essential for different industries and organizations. A possible future direction is to develop an assurance technique that can assess the competencies of the individuals for conducting the security assessment [101]. This technique will be helpful for an individual in improving security assurance skills.

10.10. Development of metrics visualization system

The security metrics measurements and meaningfulness in security assurance and risk management is a challenging task. Their poor manageability can compromise the meaningfulness of the metrics due to a large number of uncategorized information elements. Therefore, systematic methods and well-designed tools are required for better management in collecting and measuring security metrics. In the past, limited research work has been done in this area, and they are at the initial research stage [70].

10.11. Data driven security assurance method

The recent advancements in computing capabilities, software algorithms, and specialized hardware design have led to major breakthroughs in machine learning and artificial intelligence. The application of data-driven techniques in security assurance may provide a promising solution in automated and intelligent security analysis, including vulnerability identification, code classification, vulnerability prediction, code summarizing, and clone detection. In the literature, limited research work can be found in this area [23,27,97].

10.12. Vulnerability assessment

In the literature, several methods and techniques are developed to identify and predict the vulnerability. However, certain factors need to be considered while developing these methods such as "how these vulnerabilities transfer from one system to another?" and "how these vulnerabilities remain unfixed for a long time?" [95]. Another future direction is identifying the exact location of detected vulnerability in the functional level code and what it is the reason behind its detection as a vulnerability. In other words, considering and improving the localization and interpretation aspects of the vulnerability [97].

10.13. Cloud security assurance

It is a quite difficult task to enforce the security properties on a cloud platform. However, it is a complex task to describing and enforcing security properties and collection of digital evidence back. The multi-layered system and services and their interdependencies make the security evaluation even more difficult. CSPs should assess the security of their offering services. Therefore, there is a need for a method or technique that address these issues. Some other requirements are as follows:

10.13.1. Security monitoring tool

The tenants want assurance that the security properties of the requested services are enforced effectively. Therefore, CSCs should offer a tool or way so that tenants can monitor the actual security of service and can provide well-defined information regarding violations of requested security features.

10.13.2. Real-time cloud security assessment

Some security assessment methodologies have been developed in the literature, but they are worthy only if they can support the actual decision-making at run time. Most of these methods are effective in an environment where performance is not essential [49]. Therefore, an efficient method is required which support operational security assurance evaluation. Future research work should focus on the real-time monitoring of cloud security. These techniques should also include multi-cloud applications and a cloud supply chain. It should be able to adopt the changes in both cloud service composition, and the context [50].

11. Conclusion

ICT has a significant impact in this information age era. Public and private organizations heavily rely on software systems to make their business activities more manageable. However, these systems are experiencing increasing threats with the evolution of new technology; hence organizations need to expand security assurance programmes to encounter the security threats and ensure their integrity and quality. Security assurance provides confidence that the system meets the security requirements and is resilient against potential security threats and failures. It involves different processes such as requirement analysis, design, implementation, verification, and testing.

Traditional security assurance methods suffer from several limitations due to their static nature, poor security requirements specifications and design, etc. These methods are also focused on either a single application or component of a system. This paper has conducted a comprehensive SLR to study state-of-the-art, research trends and future directions in system security assurance. We have organized and presented detailed discussions on the security assurance processes and activities, such as assurance criteria, profile, methods, assurance level, system, and environments. In this paper, we have discussed the research

challenges and gaps and different security assurance techniques and methods that have made an effort to overcome these challenges. We have also discussed the limitations of these security assurance methods and future directions. The primary limitations that current approaches cannot resolve are entirely related to the security assurance specification and enforcement, correctness, effectiveness of security assurance, automation of security assurance process and real-time security assurance evaluations. Therefore, an advanced security assurance processes and methods will be required to ensure an organization's required level of security.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgements

This work was carried out during the tenure of an ERCIM 'Alain Bensoussan' Fellowship Programme. This work is also partially supported by Norwegian Cyber Range, NTNU, Norway.

Appendix. Keywords for data extraction and their definitions

1. *Challenges and Gap*
2. *Contribution*
3. *Process*: It is the series of action or steps taken in order to develop security assurance framework/evaluate the security assurance.
4. *Methods*: Which methods or techniques used for security assurance evaluation for example mathematical methods/Fuzzy Techniques/Data Driven Approach.
5. *Guidelines/Standards*: Any standards/guidelines used to define the security goals/security requirement/security metrics/assurance measurement, for example ISA/IEC 6151, ISA/IEC 62443, NIST 800-82 R2, ISA-TR84.00.09
6. *Tools*: Is there any tools which are developed or used for testing/scanning/security assurance measurement, for example: OWASP Zed Attack Proxy (ZAP), WebScarab, OpenVAS.
7. *Metrics*: Security metrics are used to diagnose issues, identify weak links in the existing security posture, facilitate benchmark comparisons, and derive performance improvement. Security metrics derived from the security objectives. In this SLR, Security Metrics are the metrics that have been considered in security assurance framework, identifying threats, security requirement and risk assessment for example: Confidentiality, Integrity, Availability, Exploitability, Vulnerability, Host Verification, Guest Verification, Reliability, authentication, authorization, etc. Some of papers may define other security metrics based on their security goals. *Note*: If the metrics are not mentioned in the general framework of the security assurance then metrics mentioned in the test cases/examples/illustration will be considered in the data sheet and the application domain will also be mentioned accordingly. In case of the more than one application domain, all the application domain and respective security metrics will be mentioned.
8. *Evaluation/Techniques*: Whether it is qualitative or quantitative?
9. *Automation*: Whether the vulnerability detection/countermeasures/ testing process or security assurance process are automated/semiautomated or manual?
10. *Application domain*
11. *Limitations and direction*
12. *Number of citations*

References

[1] S.M. Radack, et al., Managing information security risk: Organization, mission, and information system view, 2011.
[2] B. Katt, N. Prasher, Quantitative security assurance metrics: REST API case studies, in: Proceedings of the 12th European Conference on Software Architecture: Companion Proceedings, 2018, pp. 1–7.
[3] G.F. Jelen, J.R. Williams, A practical approach to measuring assurance, in: Proceedings 14th Annual Computer Security Applications Conference, Cat. No. 98EX217, IEEE, 1998, pp. 333–343.
[4] E.H. Spafford, Testimony before the house government reform committee subcommittee on technology, information policy, intergovernmental relations and the census exploring common criteria: Can it ensure that the federal government gets needed security in software? 2003.
[5] R. Heiland, B. Thomas, V. Welch, C. Jackson, Toward a research software security maturity model, 2013, arXiv preprint arXiv:1309.1677.
[6] A. Stock, D. Cuthbert, J. Manico, J. Grossman, M. Burnett, OWASP application security verification standard, 2019, Std. Rev. 4.0.1 s 70.
[7] W. Choi, D. Yoo, Software assurance towards better IT service, J. Serv. Sci. 1 (1) (2009) 31–56.
[8] M. Brown, Toward a taxonomy of communications security models, J. Cryptogr. Eng. 3 (3) (2013) 181–195.
[9] K.H. Guo, Security-related behavior in using information systems in the workplace: A review and synthesis, Comput. Secur. 32 (2013) 242–251.
[10] S. Bijani, D. Robertson, A review of attacks and security approaches in open multi-agent systems, Artif. Intell. Rev. 42 (4) (2014) 607–636.
[11] K. Wan, V. Alagar, Context-aware security solutions for cyber-physical systems, Mob. Netw. Appl. 19 (2) (2014) 212–226.
[12] H. Oueslati, M.M. Rahman, L. ben Othmane, Literature review of the challenges of developing secure software using the agile approach, in: 2015 10th International Conference on Availability, Reliability and Security, IEEE, 2015, pp. 540–547.
[13] H. Zhang, W. Han, X. Lai, D. Lin, J. Ma, J. Li, Survey on cyberspace security, Sci. China Inf. Sci. 58 (11) (2015) 1–43.
[14] S. Ouchani, M. Debbabi, Specification, verification, and quantification of security in model-based systems, Computing 97 (7) (2015) 691–711.
[15] A. Fink, Conducting Research Literature Reviews: From the Internet to Paper, Sage publications, 2019.
[16] S. Keele, et al., Guidelines for Performing Systematic Literature Reviews in Software Engineering, Technical report, Ver. 2.3 EBSE Technical Report, EBSE, 2007.
[17] B.A. Kitchenham, E. Mendes, G.H. Travassos, Cross versus within-company cost estimation studies: A systematic review, IEEE Trans. Softw. Eng. 33 (5) (2007) 316–329.
[18] M. Ouedraogo, H. Mouratidis, E. Dubois, D. Khadraoui, Information systems security criticality and assurance evaluation, in: Advances in Computer Science and Information Technology, Springer, 2010, pp. 38–54.
[19] M. Ouedraogo, H. Mouratidis, D. Khadraoui, E. Dubois, An agent-based system to support assurance of security requirements, in: 2010 Fourth International Conference on Secure Software Integration and Reliability Improvement, IEEE, 2010, pp. 78–87.
[20] A. Hecker, M. Riguidel, On the operational security assurance evaluation of networked IT systems, in: Smart Spaces and Next Generation Wired/Wireless Networking, Springer, 2009, pp. 266–278.
[21] M. Ouedraogo, D. Khadraoui, B. De Rémont, E. Dubois, H. Mouratidis, Deployment of a security assurance monitoring framework for telecommunication service infrastructures on a VoIP service, in: 2008 New Technologies, Mobility and Security, IEEE, 2008, pp. 1–5.
[22] C.A. Ardagna, E. Damiani, J. Schütte, P. Stephanow, A case for IoT security assurance, in: Internet of Everything, Springer, 2018, pp. 175–192.
[23] R. Kumar, A.I. Khan, Y.B. Abushark, M.M. Alam, A. Agrawal, R.A. Khan, A knowledge-based integrated system of hesitant fuzzy set, AHP and TOPSIS for evaluating security-durability of web applications, IEEE Access 8 (2020) 48870–48885.
[24] Y. Liu, K.P. Gummadi, B. Krishnamurthy, A. Mislove, Analyzing facebook privacy settings: user expectations vs. reality, in: Proceedings of the 2011 ACM SIGCOMM Conference on Internet Measurement Conference, 2011, pp. 61–70.
[25] R. Tilson, J. Dong, S. Martin, E. Kieke, Factors and principles affecting the usability of four e-commerce sites, in: Proceedings of the 4th Conference on Human Factors & the Web, Basking Ridge, New Jersey. Retrieved July, Vol. 3, 1998, p. 2005.
[26] G. Karjoth, B. Pfitzmann, M. Schunter, M. Waidner, Service-oriented assurance comprehensive security by explicit assurances, Proc. QoP 5 (2005).
[27] R.K. Sakthivel, G. Nagasubramanian, F. Al-Turjman, M. Sankayya, Core-level cybersecurity assurance using cloud-based adaptive machine learning techniques for manufacturing industry, Trans. Emerg. Telecommun. Technol. (2020) e3947.

[28] S.H. Kim, C.S. Leem, A case study in applying common criteria to development process to improve security of software products, in: International Conference on Computational Science and Its Applications, Springer, 2004, pp. 1069–1077.
[29] D. Mellado, E. Fernández-Medina, M. Piattini, A common criteria based security requirements engineering process for the development of secure information systems, Comput. Stand. Interfaces 29 (2) (2007) 244–253.
[30] A. Ekclhart, S. Fenz, G. Goluch, E. Weippl, Ontological mapping of common criteria's security assurance requirements, in: IFIP International Information Security Conference, Springer, 2007, pp. 85–95.
[31] K.-s. Kou, G.-s. Lee, Modeling and analysis of CC-based security assurance for composed systems, in: 2008 Second International Conference on Future Generation Communication and Networking, Vol. 2, IEEE, 2008, pp. 106–111.
[32] S.H. Houmb, S. Islam, E. Knauss, J. Jürjens, K. Schneider, Eliciting security requirements and tracing them to design: an integration of common criteria, heuristics, and UMLsec, Requir. Eng. 15 (1) (2010) 63–93.
[33] K. Taguchi, N. Yoshioka, T. Tobita, H. Kaneko, Aligning security requirements and security assurance using the common criteria, in: 2010 Fourth International Conference on Secure Software Integration and Reliability Improvement, IEEE, 2010, pp. 69–77.
[34] H. Kim, A framework for security assurance in component based development, in: International Conference on Computational Science and Its Applications, Springer, 2004, pp. 587–596.
[35] T.-h. Kim, S.-y. Lee, Security evaluation targets for enhancement of IT systems assurance, in: International Conference on Computational Science and Its Applications, Springer, 2005, pp. 491–498.
[36] N. Pham, M. Riguidel, Security assurance aggregation for it infrastructures, in: 2007 Second International Conference on Systems and Networks Communications, ICSNC 2007, IEEE, 2007, p. 72.
[37] S. Haddad, S. Dubus, A. Hecker, T. Kanstrén, B. Marquet, R. Savola, Operational security assurance evaluation in open infrastructures, in: 2011 6th International Conference on Risks and Security of Internet and Systems, CRiSIS, IEEE, 2011, pp. 1–6.
[38] M. Ouedraogo, D. Khadraoui, H. Mouratidis, E. Dubois, Appraisal and reporting of security assurance at operational systems level, J. Syst. Softw. 85 (1) (2012) 193–208.
[39] N. Pham, L. Baud, P. Bellot, M. Riguidel, A near real-time system for security assurance assessment, in: 2008 the Third International Conference on Internet Monitoring and Protection, IEEE, 2008, pp. 152–160.
[40] E. Deveci, M.U. Caglayan, Model driven security framework for software design and verification, Secur. Commun. Netw. 8 (16) (2015) 2768–2792.
[41] H. Löhr, A.-R. Sadeghi, C. Stüble, M. Weber, M. Winandy, Modeling trusted computing support in a protection profile for high assurance security kernels, in: International Conference on Trusted Computing, Springer, 2009, pp. 45–62.
[42] R.M. Savola, Software security assurance of telecommunication systems, in: 2009 International Conference on Multimedia Computing and Systems, IEEE, 2009, pp. 138–143.
[43] I. Rauf, E. Troubitsyna, Towards a model-driven security assurance of open source components, in: International Workshop on Software Engineering for Resilient Systems, Springer, 2017, pp. 65–80.
[44] A. Hovsepyan, R. Scandariato, W. Joosen, Is newer always better? The case of vulnerability prediction models, in: Proceedings of the 10th ACM/IEEE International Symposium on Empirical Software Engineering and Measurement, 2016, pp. 1–6.
[45] R.A. Khan, S.U. Khan, A preliminary structure of software security assurance model, in: Proceedings of the 13th International Conference on Global Software Engineering, 2018, pp. 137–140.
[46] J.L. Vivas, I. Agudo, J. López, A methodology for security assurance-driven system development, Requir. Eng. 16 (1) (2011) 55–73.
[47] J.A. Pavlich-Mariscal, S.A. Demurjian, L.D. Michel, A framework for security assurance of access control enforcement code, Comput. Secur. 29 (7) (2010) 770–784.
[48] A. Bousquet, J. Briffaut, E. Caron, E.M. Dominguez, J. Franco, A. Lefray, O. López, S. Ros, J. Rouzaud-Cornabas, C. Toinard, et al., Enforcing security and assurance properties in cloud environment, in: 2015 IEEE/ACM 8th International Conference on Utility and Cloud Computing, UCC, IEEE, 2015, pp. 271–280.
[49] J. Modic, R. Trapero, A. Taha, J. Luna, M. Stopar, N. Suri, Novel efficient techniques for real-time cloud security assessment, Comput. Secur. 62 (2016) 1–18.
[50] E. Rios, E. Iturbe, W. Mallouli, M. Rak, Dynamic security assurance in multi-cloud DevOps, in: 2017 IEEE Conference on Communications and Network Security, CNS, IEEE, 2017, pp. 467–475.
[51] S. Formoso, M. Felici, Evidence-based security and privacy assurance in cloud ecosystems, in: IFIP International Summer School on Privacy and Identity Management, Springer, 2015, pp. 205–219.
[52] L. Bobelin, A. Bousquet, J. Briffaut, An autonomic cloud management system for enforcing security and assurance properties, in: Proceedings of the 2015 Workshop on Changing Landscapes in HPC Security, 2015, pp. 1–8.
[53] U.M. Ismail, S. Islam, A unified framework for cloud security transparency and audit, J. Inf. Secur. Appl. 54 (2020) 102594.
[54] I. Tashi, S. Ghernaouti-Hélie, A security assurance model to holistically assess the information security posture, in: Complex Intelligent Systems and their Applications, Springer, 2010, pp. 83–108.
[55] A. Hudic, P. Smith, E.R. Weippl, Security assurance assessment methodology for hybrid clouds, Comput. Secur. 70 (2017) 723–743.
[56] G.-B. Jeong, G.-B. Kim, A framework for security assurance in component based development, in: International Conference on Computational Science and Its Applications, Springer, 2005, pp. 42–51.
[57] R.Z. Naeem, H. Abbas, N. Shafqat, K. Saleem, W. Iqbal, A framework to determine applications' authenticity, Procedia Comput. Sci. 155 (2019) 268–275.
[58] W.A. Al-Hamdani, Non risk assessment information security assurance model, in: 2009 Information Security Curriculum Development Conference, 2009, pp. 84–90.
[59] R.M. Savola, H. Pentikäinen, M. Ouedraogo, Towards security effectiveness measurement utilizing risk-based security assurance, in: 2010 Information Security for South Africa, IEEE, 2010, pp. 1–8.
[60] V. Sklyar, V. Kharchenko, Challenges in assurance case application for industrial IoT, in: 2017 9th IEEE International Conference on Intelligent Data Acquisition and Advanced Computing Systems: Technology and Applications, Vol. 2, IDAACS, IEEE, 2017, pp. 736–739.
[61] A. Agrawal, M. Alenezi, S.A. Khan, R. Kumar, R.A. Khan, Multi-level fuzzy system for usable-security assessment, J. King Saud Univ. Comput. Inf. Sci. (2019).
[62] J. Gutiérrez-Martínez, M.A. Núñez-Gaona, H. Aguirre-Meneses, Business model for the security of a large-scale PACS, compliance with ISO/27002: 2013 standard, J. Digit. Imag. 28 (4) (2015) 481–491.
[63] M. Debbabi, M. Saleh, C. Talhi, S. Zhioua, Embedded Java Security: Security for Mobile Devices, Springer Science & Business Media, 2007.
[64] E.D. Knapp, J.T. Langill, Industrial Network Security: Securing Critical Infrastructure Networks for Smart Grid, SCADA, and Other Industrial Control Systems, Syngress, 2014.
[65] M. Chapple, J.M. Stewart, D. Gibson, (ISC) 2 CISSP Certified Information Systems Security Professional Official Study Guide, John Wiley & Sons, 2018.
[66] R. Darimont, E. Delor, P. Massonet, A. van Lamsweerde, GRAIL/KAOS: an environment for goal-driven requirements engineering, in: Proceedings of the 19th International Conference on Software Engineering, 1997, pp. 612–613.
[67] H. Mouratidis, P. Giorgini, Secure tropos: a security-oriented extension of the tropos methodology, Int. J. Softw. Eng. Knowl. Eng. 17 (02) (2007) 285–309.
[68] T. Kanstrén, R. Savola, A. Evesti, H. Pentikäinen, A. Hecker, M. Ouedraogo, K. Hätönen, P. Halonen, C. Blad, O. López, et al., Towards an abstraction layer for security assurance measurements, in: Proceedings of the Fourth European Conference on Software Architecture: Companion Volume, 2010, pp. 189–196.
[69] M.M. Swanson, N. Bartol, J. Sabato, J. Hash, L. Graffo, Security Metrics Guide for Information Technology Systems, Technical Report, 2003.
[70] R.M. Savola, P. Heinonen, A visualization and modeling tool for security metrics and measurements management, in: 2011 Information Security for South Africa, IEEE, 2011, pp. 1–8.
[71] M. Ouedraogo, H. Mouratidis, D. Khadraoui, E. Dubois, A risk based approach for security assurance evaluation of IT systems, in: 2009 Seventh Annual Communication Networks and Services Research Conference, IEEE, 2009, pp. 428–430.
[72] M. Ouedraogo, H. Mouratidis, A. Hecker, C. Bonhomme, D. Khadraoui, E. Dubois, D. Preston, A new approach to evaluating security assurance, in: 2011 7th International Conference on Information Assurance and Security, IAS, IEEE, 2011, pp. 215–221.
[73] M. Ouedraogo, R.M. Savola, H. Mouratidis, D. Preston, D. Khadraoui, E. Dubois, Taxonomy of quality metrics for assessing assurance of security correctness, Softw. Qual. J. 21 (1) (2013) 67–97.
[74] T. Kanstrén, A. Evesti, Security metrics, secure elements, and operational measurement trust in cloud environments, in: International Workshop on Security and Trust Management, Springer, 2015, pp. 37–51.
[75] S. Rizvi, J. Ryoo, J. Kissell, W. Aiken, Y. Liu, A security evaluation framework for cloud security auditing, J. Supercomput. 74 (11) (2018) 5774–5796.
[76] B. Marquet, S. Dubus, C. Blad, Security assurance profile for large and heterogeneous telecom and IT infrastructures, in: Proceedings of the International Symposium on Risk Management and Cyber-Informatics (RMCI'10), Orlando, Florida, USA, 2010, 2010.

[77] H.-H. Bock, J. Braband, B. Milius, H. Schäbe, Towards an IT security protection profile for safety-related communication in railway automation, in: International Conference on Computer Safety, Reliability, and Security, Springer, 2012, pp. 137–148.
[78] G. Tanna, M. Gupta, H.R. Rao, S. Upadhyaya, Information assurance metric development framework for electronic bill presentment and payment systems using transaction and workflow analysis, Decis. Support Syst. 41 (1) (2005) 242–261.
[79] A. Ray, R. Cleaveland, Security assurance cases for medical cyber–physical systems, IEEE Des. Test 32 (5) (2015) 56–65.
[80] R. Gupta, S.K. Pal, S.K. Muttoo, Cyber security assessment education for E-governance systems, in: Innovations in Cybersecurity Education, Springer, 2020, pp. 181–212.
[81] S. Jaiswal, D. Gupta, Engineering and validating security to make cloud secure, Int. J. Syst. Assur. Eng. Manag. 8 (2) (2017) 1419–1441.
[82] S.W. Cadzow, Securitv assurance and standards-design for evaluation, in: The 2nd IEE Secure Mobile Communications Forum: Exploring the Technical Challenges in Secure GSM and WLAN, 2004, Ref. No. 2004/10660, IET, 2004, pp. 1–8.
[83] D.S. Yavagal, S.W. Lee, G.-J. Ahn, R.A. Gandhi, Common criteria requirements modeling and its uses for quality of information assurance (QoIA), in: Proceedings of the 43rd Annual Southeast Regional Conference, Vol. 2, 2005, pp. 130–135.
[84] A. Baldwin, Y. Beres, S. Shiu, P. Kearney, A model-based approach to trust, security and assurance, BT Technol. J. 24 (4) (2006) 53–68.
[85] X.-H. Wu, J.-P. Li, W. Yao, A network security evaluation model based on common criteria, in: 2008 International Conference on Apperceiving Computing and Intelligence Analysis, IEEE, 2008, pp. 416–420.
[86] L. Xiang, The analysis and construction E-government information security assurance system, in: 2010 Second International Conference on Communication Systems, Networks and Applications, 2010.
[87] Y. Lan, T. Han, SADP: Security assurance development process for building reliable linux-based operating system, in: 2015 IEEE International Conference on Computer and Communications, ICCC, IEEE, 2015, pp. 50–55.
[88] A. Bialas, M. Michalak, B. Flisiuk, Anomaly detection in network traffic security assurance, in: International Conference on Dependability and Complex Systems, Springer, 2019, pp. 46–56.
[89] V. Diamantopoulou, C. Kalloniatis, C. Lyvas, K. Maliatsos, M. Gay, A. Kanatas, C. Lambrinoudakis, Aligning the concepts of risk, security and privacy towards the design of secure intelligent transport systems, in: Computer Security, Springer, 2020, pp. 170–184.
[90] X. Cuihua, L. Jiajun, An object-oriented information system security evaluation method based on security level distinguishing model, in: 2009 International Conference on Web Information Systems and Mining, IEEE, 2009, pp. 497–500.
[91] H.-K. Kim, T.-H. Kim, J.-s. Kim, Reliability assurance in development process for TOE on the common criteria, in: International Conference on Software Engineering Research and Applications, Springer, 2003, pp. 364–375.
[92] M. Maidl, D. Von Oheimb, P. Hartmann, R. Robinson, Formal security analysis of electronic software distribution systems, in: International Conference on Computer Safety, Reliability, and Security, Springer, 2008, pp. 415–428.
[93] N. Hubballi, A.K. Patel, A.K. Meena, N. Tripathi, Cloud security service level agreements: Representation and measurement, in: IEEE INFOCOM 2019-IEEE Conference on Computer Communications Workshops, INFOCOM WKSHPS, IEEE, 2019, pp. 145–150.
[94] I. Drago, M. Mellia, M. M. Munafo, A. Sperotto, R. Sadre, A. Pras, Inside dropbox: understanding personal cloud storage services, in: Proceedings of the 2012 Internet Measurement Conference, 2012, pp. 481–494.
[95] J. Akram, P. Luo, SQVDT: A scalable quantitative vulnerability detection technique for source code security assessment, Softw. - Pract. Exp. 51 (2) (2021) 294–318.
[96] A.M. Dissanayaka, S. Mengel, L. Gittner, H. Khan, Security assurance of MongoDB in singularity LXCs: an elastic and convenient testbed using linux containers to explore vulnerabilities, Cluster Comput. 23 (3) (2020) 1955–1971.
[97] Z. Bilgin, M.A. Ersoy, E.U. Soykan, E. Tomur, P. Çomak, L. Karaçay, Vulnerability prediction from source code using machine learning, IEEE Access 8 (2020) 150672–150684.
[98] M. Cheah, S.A. Shaikh, J. Bryans, P. Wooderson, Building an automotive security assurance case using systematic security evaluations, Comput. Secur. 77 (2018) 360–379.
[99] Y.-W. Huang, C.-H. Tsai, T.-P. Lin, S.-K. Huang, D. Lee, S.-Y. Kuo, A testing framework for web application security assessment, Comput. Netw. 48 (5) (2005) 739–761.
[100] P. Krishnan, S. Hafner, A. Zeiser, Applying security assurance techniques to a mobile phone application: An initial approach, in: 2011 IEEE Fourth International Conference on Software Testing, Verification and Validation Workshops, IEEE, 2011, pp. 545–552.
[101] W. Knowles, J.M. Such, A. Gouglidis, G. Misra, A. Rashid, Assurance techniques for industrial control systems (ics), in: Proceedings of the First ACM Workshop on Cyber-Physical Systems-Security and/Or PrivaCy, 2015, pp. 101–112.
[102] S. Jahan, I. Riley, C. Walter, R.F. Gamble, M. Pasco, P.K. McKinley, B.H. Cheng, MAPE-K/MAPE-SAC: An interaction framework for adaptive systems with security assurance cases, Future Gener. Comput. Syst. 109 (2020) 197–209.
[103] R. Trapero, J. Modic, M. Stopar, A. Taha, N. Suri, A novel approach to manage cloud security SLA incidents, Future Gener. Comput. Syst. 72 (2017) 193–205.
[104] M. Beynon, B. Curry, P. Morgan, The Dempster–Shafer theory of evidence: an alternative approach to multicriteria decision modelling, Omega 28 (1) (2000) 37–50.
[105] I. Somarakis, M. Smyrlis, K. Fysarakis, G. Spanoudakis, Model-driven cyber range training: a cyber security assurance perspective, in: Computer Security, Springer, 2019, pp. 172–184.
[106] Y.-l. Liu, Z.-g. Jin, SAEW: A security assessment and enhancement system of Wireless Local Area networks (WLANs), Wirel. Pers. Commun. 82 (1) (2015) 1–19.
[107] L.O. Nweke, P. Yeng, S. Wolthusen, B. Yang, Understanding Attribute-based Access Control for Modelling and Analysing Healthcare Professionals' Security Practices, SAI Organization, 2020.
[108] P.T. Devanbu, S. Stubblebine, Software engineering for security: a roadmap, in: Proceedings of the Conference on the Future of Software Engineering, 2000, pp. 227–239.
[109] D.T. Le, Quality trade-offs in self-protecting system, in: 2015 IEEE International Conference on Self-Adaptive and Self-Organizing Systems Workshops, IEEE, 2015, pp. 152–156.
[110] D.S. Herrmann, Using the Common Criteria for IT Security Evaluation, CRC Press, 2002.